

LAB 3 : TokTickIT Authenticated IT Ticketing System

Final submission report - authenticated users, IT Staff ticketing, Administrator safety, and release evidence

Student Name: Thira Rungruangkaset	Student ID: 67070503419
GitHub Username: HolyThiccDaddy	Peer Reviewer: Ashira Sangkaset (67070503445)

Answer Part 1: Git Use with Engineering Workflow (10 Points)

Lab 3 was developed on issue-specific branches, reviewed through pull requests, integrated into lab3-staging, and released to main. The final release is PR #46 at commit 92fac36.

Evidence	Link
GitHub repository	HolyThiccDaddy/toktickit
GitHub project board	TokTickIT Individual Sprints
Issue #36 - authentication and migration	Issue #36
Issue #37 - requester authorization regression	Issue #37
Issue #38 - staff queue and ticket operations	Issue #38
Issue #39 - Administrator and release evidence	Issue #39
Final release PR #46	PR #46 - merged into main

Final release status: PR #46 was peer-approved and merged into main as 92fac36. The documentation follow-up in this report is submitted separately as PR #47.

Answer Part 1: Git Use with Engineering Workflow (continued)

Peer-review and release history

Stage	Pull request and result
Contract	PR #40 approved and merged as 40ca398.
Authentication and migration	PR #41 merged as b49c8b2 after credential and path-gate fixes.
Requester regression	PR #42 merged as 0ee0002.
Staff queue	PR #43 merged as c1cd708.
Administrator implementation	PR #44 approved after requested changes and merged as bd5872a.
Documentation follow-up	PR #45 approved and merged as e82ac21.
Final integration	PR #46 approved and merged into main as 92fac36.

The reviewer record identifies requested changes, responses, approval reviews, and merge commits. The final board and branch state are recorded in the source documents linked in Parts 2 and 3.

Answer Part 2: Spec DD

The approved contract was reviewed before implementation in PR #40. It defines numbered FR/BR/AC requirements, an authorization matrix, data migration, API/UI contracts, tests, and Definition of Done. The readable contract extracts appear in the appendix.

Specification	docs/lab-03/specification.md Scope, roles, rules, migration, ACs and DoD
API contract	docs/lab-03/api-spec.md Schemas, status codes and authorization
UI contract	docs/lab-03/ui-spec.md Screens, states and responsive acceptance
Test plan	docs/lab-03/tests.md AC-to-test traceability and release checks

Release and report provenance

Core Lab 3 implementation was merged to main at 92fac36; documentation followed at e7998d3.

This expanded PDF and its local verification were prepared on feature/lab3-final-evidence.

They are not described as merged or submitted on main until a later integration check.

The test totals are evidence from the stated checkout, not a substitute for a post-merge run.

Answer Part 3: Test DD and Traceability (10 Points)

Verification results from the merged Lab 3 release

Check	Executed result
Server regression	15 test files / 92 tests passed twice against the dedicated _test database.
Client regression	15 test files / 50 tests passed twice; the Create Ticket loading race is stabilized.
Server production build	TypeScript production build passed.
Client production build	TypeScript and Vite production build passed.
Playwright E2E	13 tests passed across desktop, tablet, and mobile projects.
Migration and seed	Seven migration/regression tests passed, including preserved Lab 2 rows, collision-safe IDs, pending credentials, and deterministic reseeding.
Repository hygiene	git diff --check passed for source documentation; local environment files and credentials remain ignored.

Acceptance-criterion traceability

Criteria	Evidence mapped in tests.md
AC-01 to AC-04	Login, first-login password gate, logout/expiry, CSRF, and role-aware session APIs and UI tests.
AC-05 to AC-06	Requester ownership, comments, resolution indication, attachment compatibility, and regression E2E.
AC-07 to AC-09	Shared queue, staff detail, assignment, IT Priority, status matrix, public comments, and Internal Notes.
AC-10 to AC-13	Administrator listing/filtering, create/edit/activation/reset, safety protections, migration, and forged-identity rejection.
AC-14 to AC-15	Responsive screenshots, visual checks, complete regression suites, production builds, and release integration.

Detailed test-file paths and command results are maintained in [docs/lab-03/tests.md](https://github.com/department-of-homeland-security/dhs-secure/blob/master/docs/lab-03/tests.md).

Answer Part 4: AI Use with Reflection (5 Points)

LLM used: OpenAI Codex (GPT-5). The agent output was treated as a draft and accepted only after comparison with Lab_3_sheet.pdf, the approved contract, executable tests, real terminal evidence, and peer-review feedback.

#	Selected prompt and accepted result
1	Convert the Lab 3 handout into a traceable product increment, issue plan, and Definition of Done.
2	Draft the engineering contract for authentication, role authorization, migration, queue/detail, comments/notes, and Administrator safety.
3	Implement the server foundation with sessions, password gate, CSRF, migration compatibility, and regression tests.
4	Implement requester authorization and communication while preserving Lab 2 ownership and attachment behavior.
5	Design Staff Queue, Ticket Detail, User Management states, responsive layouts, and safe failure feedback.
6	Map every acceptance criterion to unit, API, UI, security, migration, responsive, and E2E checks.
7	Recheck peer-review comments for contract, migration, authorization, concurrency, filtering, and E2E evidence gaps.
8	Audit release evidence for source/test-count consistency and final-main readiness.

My Reflection

Codex was most useful for turning the handout into a traceable contract, finding mismatches between requirements and tests, and generating focused regression cases. Human decisions and peer review remained authoritative: authorization, migration safety, password handling, and status transitions were accepted only after executable tests and real evidence passed. Suggestions that weakened server-side checks, exposed credentials, relied on hidden UI controls, or added excluded features were changed or rejected. The final release was rechecked from merged main before this report was generated.

Answer Part 5: Working Login and Password Change UI

The old three-image Sign in triptych only showed responsive layout. These live-app states demonstrate invalid and valid credentials, inactive-account rejection, and the mandatory first-login gate.

01. Invalid login

TokTickIT

Sign in to IT Service Desk

Use your TokTickIT account to view and manage your requests.

Invalid email or password

Email

not-a-user@example.com

Password

.....

Show

[Retry sign in](#)

Sign in

Safe error and Retry sign in remain visible.

02. Inactive account

TokTickIT

Sign in to IT Service Desk

Use your TokTickIT account to view and manage your requests.

This account is inactive

Email

inactive.staff@example.com

Password

.....

Show

[Retry sign in](#)

Sign in

The seeded inactive IT Staff account is refused.

03. Valid credentials entered

TokTickIT

Sign in to IT Service Desk

Use your TokTickIT account to view and manage your requests.

Email

admin@example.com

Password

.....

Show

Sign in

Active Administrator email; password masked.

04. First-login gate

TokTickIT

Change your password

Your account requires a password change before you can access tickets.

Current password

New password

Use 12-128 characters.

Confirm new password

Update password

Sign out

Signed in as admin@example.com

Valid login opens change-password, not app data.

Answer Part 5: Working Login and Password Change UI (continued)

The same E2E journey fills the required fields, saves a new password, opens the role-aware workspace, then signs out and navigates directly to / again. Field values remain masked in the captures.

05. Change-password form

TokTickIT

Change your password

Your account requires a password change before you can access tickets.

Current password

.....

New password

.....

Use 12-128 characters.

Confirm new password

.....

Update password

Sign out

Signed in as admin@example.com

Current, new, and confirmation values are masked.

07. After logout and direct visit

TokTickIT

Sign in to IT Service Desk

Use your TokTickIT account to view and manage your requests.

Email

Password

Show

Sign in

The protected workspace is gone; Sign in returns.

06. Password saved: authenticated ADMIN workspace

TokTickIT

User ManagementTicket Queue

TokTickIT AdministratorADMINSign out

User Management

Manage roles and account activation without exposing credentials.

ADMIN

Search users

Name or email

Role

All roles

Create user

Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active Password change required	EditDeactivate Reset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active Password change required	EditDeactivate Reset password

The role-aware header, User Management, ADMIN badge, and Sign out are visible.

Verification: e2e/lab-03/authentication.spec.ts passed 1/1 in this local capture run. Busy, validation, session, and direct API authorization are additionally covered by the Login, ChangePassword, auth API, and authorization test suites; still images alone do not prove them.

Answer Part 6: Working IT Staff Ticket Queue UI

The shared queue is exercised against live local test data, including 21 requester-created pagination fixtures. Search, status/priority filters, sorting, assigned/unassigned rows, no-results feedback, and an explicitly simulated retry state are visible below.

Rubric / state	Evidence and provenance
Loaded queue and result count	Fig 6.1; staff-ticket-flow E2E
Search, status/priority filters, sorting	Fig 6.2; queue API/component tests
No results and clear filters	Fig 6.3; component tests
API error and retry	Fig 6.4; intercepted 503, explicitly simulated
Assigned/unassigned and page 1/2 navigation	Fig 6.5-6.7; staff-ticket-flow E2E
Mobile cards and sorting controls	staff-ticket-flow E2E; responsive.visual E2E

Evidence key: figures are screenshots from the real local UI and a seeded _test database.
The only simulated response is Fig 6.4, deliberately intercepted to verify safe retry UI.
Claims without a matching figure are backed by named executable tests, not inferred from images.

Answer Part 6: Working IT Staff Ticket Queue UI (evidence)

Figure 6.1. Loaded shared queue

Live local app with seeded and newly submitted tickets.
Source: artifacts/lab-03/screenshots/staff-flow/states/01_queue_loaded.png

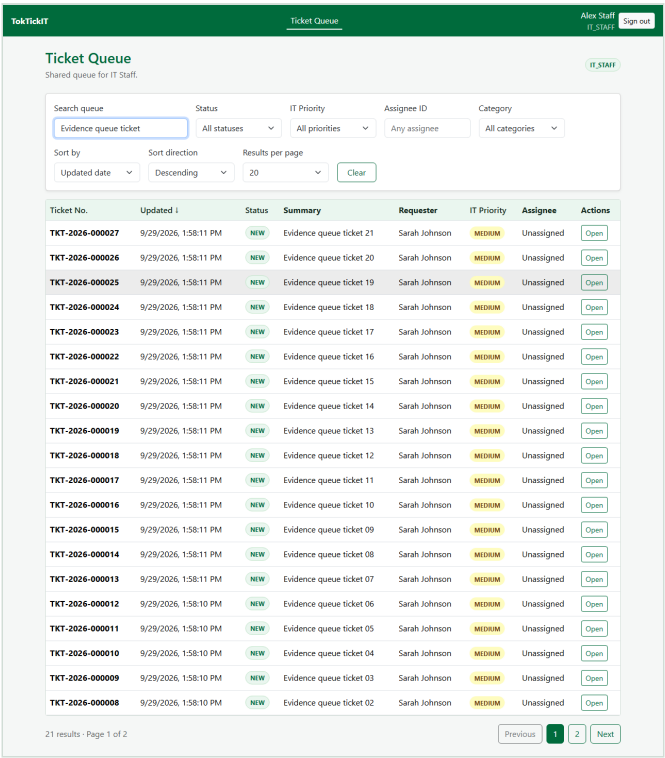
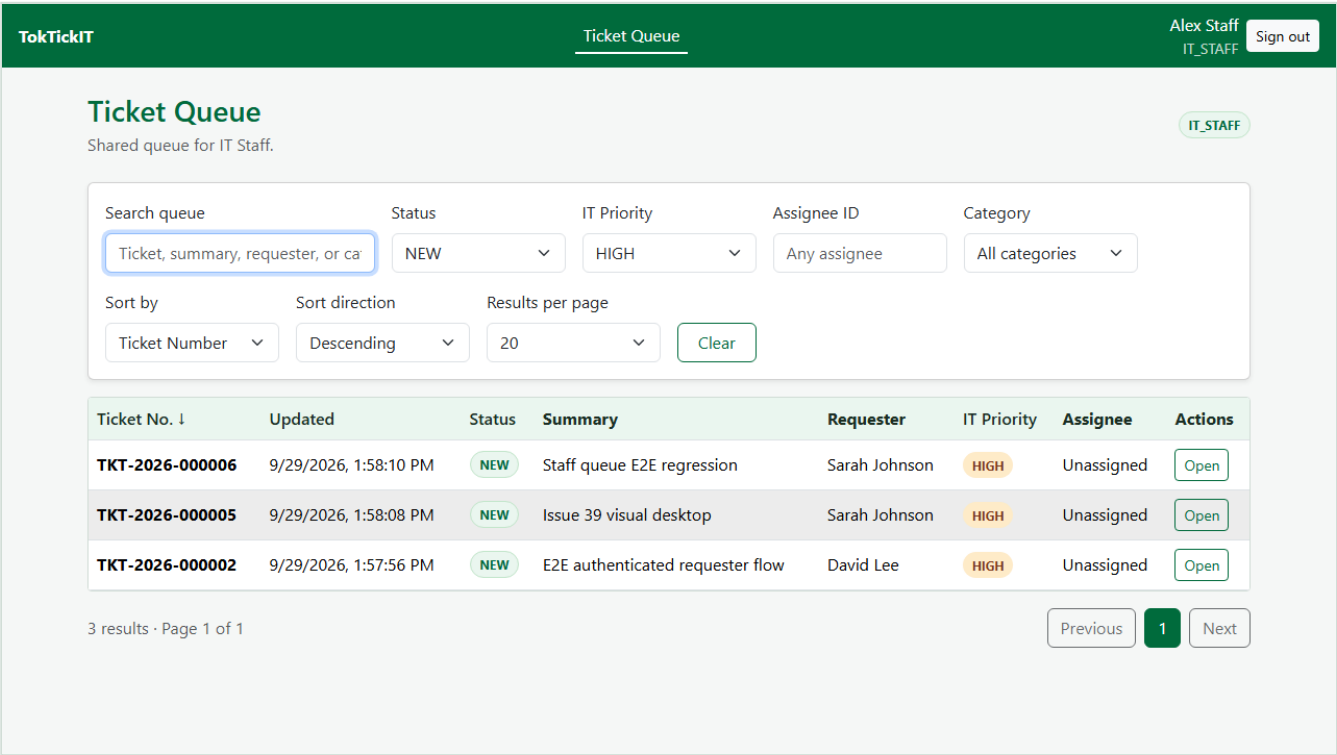


Figure 6.2. Filtered and sorted queue

NEW + HIGH filters and Ticket Number sort; matching E2E ticket remains visible.
Source: artifacts/lab-03/screenshots/staff-flow/states/02_queue_filter_sort.png



Answer Part 6: Working IT Staff Ticket Queue UI (evidence)

Figure 6.3. No matching results

A real unmatched search shows the empty-result message and Clear filters.

Source: artifacts/lab-03/screenshots/staff-flow/states/03_queue_no_results.png

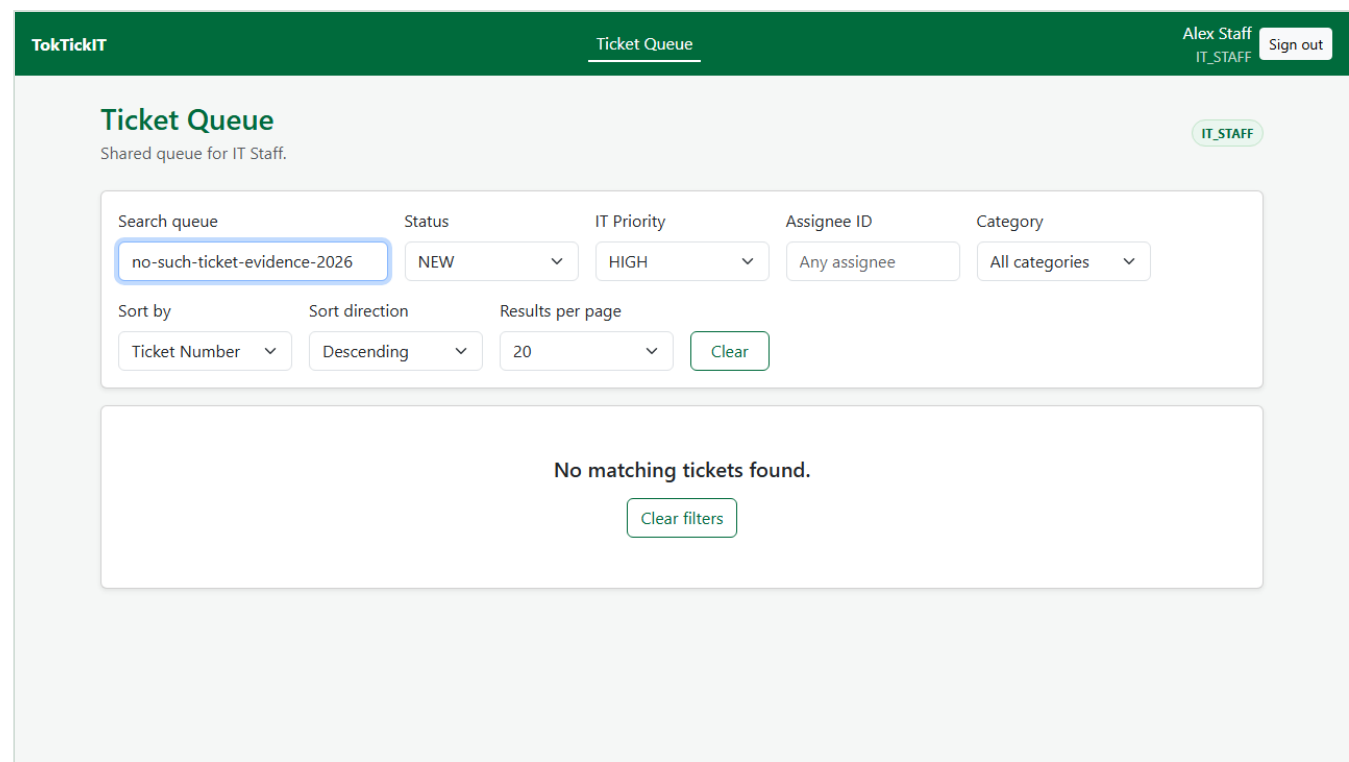
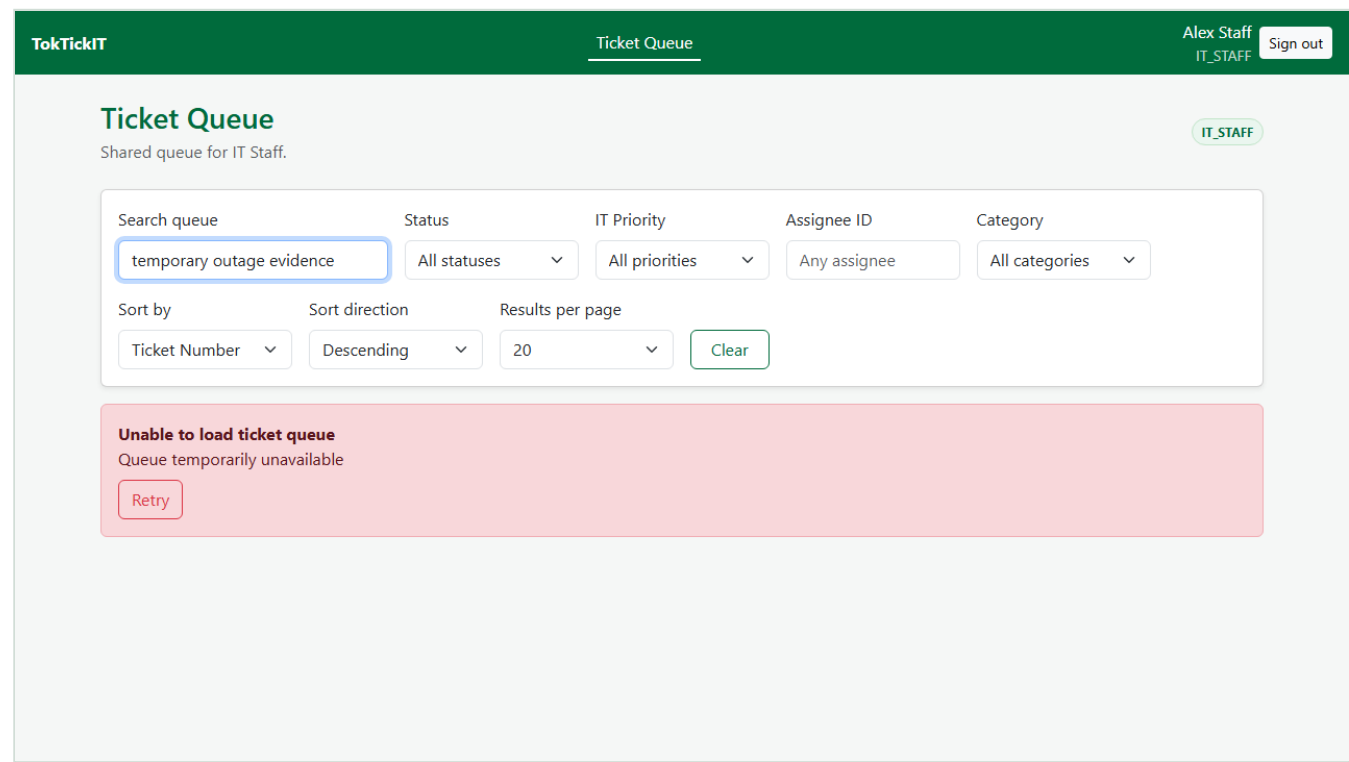


Figure 6.4. Retryable API failure

Simulated 503 via Playwright network interception; UI displays safe error and Retry.

Source: artifacts/lab-03/screenshots/staff-flow/states/04_queue_retry_simulated_api_failure.png



Answer Part 6: Working IT Staff Ticket Queue UI (evidence)

Figure 6.5. Pagination: page 1 of 2

21 matching tickets were created via the authenticated requester API in the E2E run.

Source: artifacts/lab-03/screenshots/staff-flow/states/05_queue_page_1_of_2.png

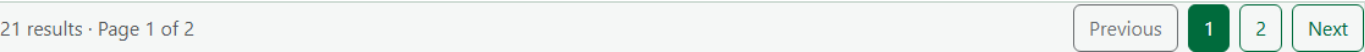
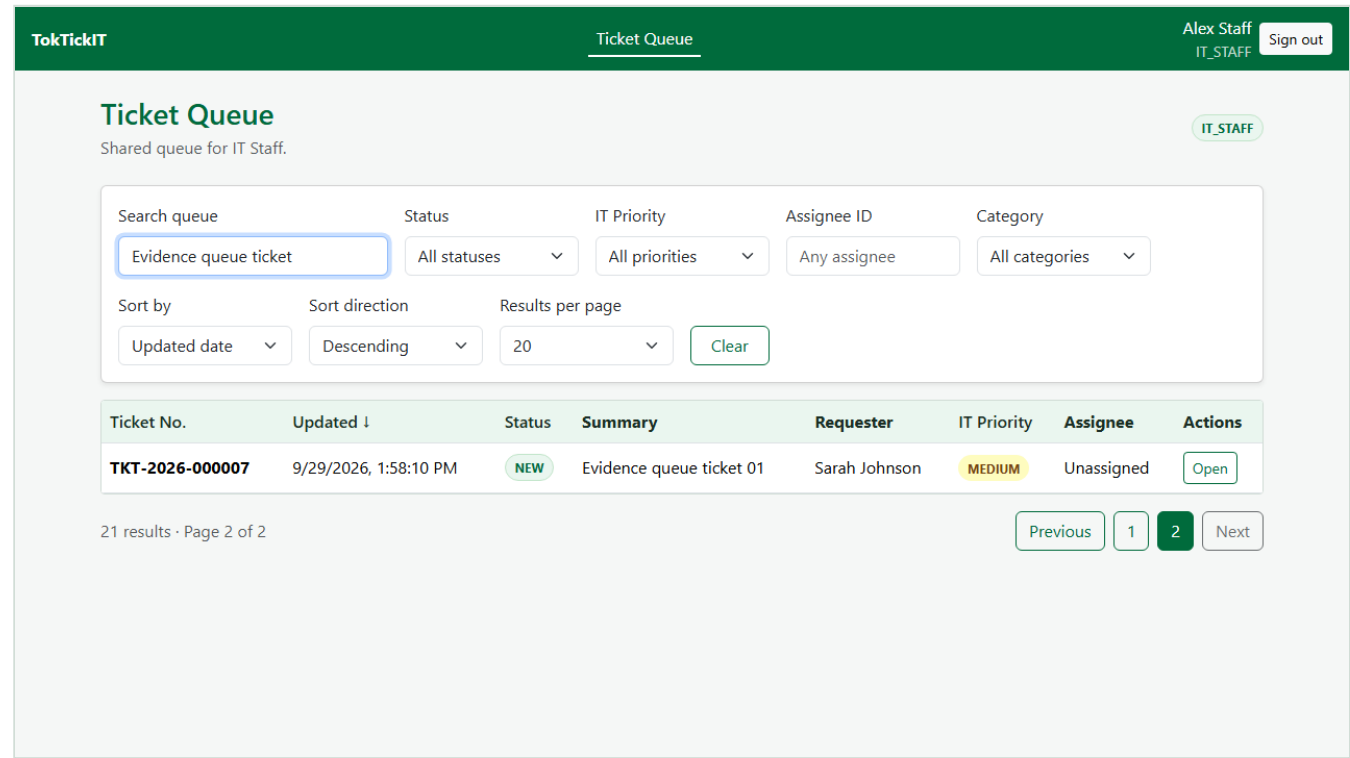


Figure 6.6. Pagination: page 2 of 2

The Next/Page 2 control loads the remaining real test-database ticket.

Source: artifacts/lab-03/screenshots/staff-flow/states/06_queue_page_2_of_2.png



Answer Part 6: Working IT Staff Ticket Queue UI (evidence)

Figure 6.7. Assigned and unassigned rows

The reassigned ticket shows Casey Staff while another row remains Unassigned.

Source: artifacts/lab-03/screenshots/staff-flow/states/07_queue_assigned_unassigned.png

TokTickIT

Ticket Queue

Alex Staff
IT_STAFF

Sign out

Ticket Queue

Shared queue for IT Staff.

IT_STAFF

Search queue

Status

IT Priority

Assignee ID

Category

Ticket, summary, requester, or ca

All statuses

All priorities

Any assignee

All categories

Sort by

Sort direction

Results per page

Clear

Ticket Number

Ascending

20

Ticket No. 1	Updated	Status	Summary	Requester	IT Priority	Assignee	Actions
TKT-2026-000001	9/29/2026, 1:57:54 PM	NEW	Authenticated ownership isolation	Jennifer Anderson	LOW	Unassigned	Open
TKT-2026-000002	9/29/2026, 1:57:56 PM	NEW	E2E authenticated requester flow	David Lee	HIGH	Unassigned	Open
TKT-2026-000003	9/29/2026, 1:57:57 PM	NEW	Responsive desktop ticket	Jennifer Anderson	MEDIUM	Unassigned	Open
TKT-2026-000004	9/29/2026, 1:58:02 PM	NEW	Requester communication regression	Sarah Johnson	MEDIUM	Unassigned	Open
TKT-2026-000005	9/29/2026, 1:58:08 PM	NEW	Issue 39 visual desktop	Sarah Johnson	HIGH	Unassigned	Open
TKT-2026-000006	9/29/2026, 1:58:15 PM	RESOLVED	Staff queue E2E regression	Sarah Johnson	URGENT	Casey Staff	Open

Answer Part 7: Working IT Staff Ticket Detail UI

One real ticket travels from Requester creation into the Staff detail. Its attachment is still available; Staff claims it, changes IT Priority, follows permitted status transitions, confirms RESOLVED, and adds public and staff-only communication.

Rubric / state	Evidence and provenance
Ticket identity, metadata, attachment	Fig 7.1; requester-to-staff E2E
Claim / owner state	Fig 7.2; staff queue + detail API tests
Priority, legal status transitions	Fig 7.2-7.3; BR-08 API matrix
Confirmation before RESOLVED	Fig 7.3; blocked action then confirmed E2E
Public comment and internal note	Fig 7.4-7.5; visibility API tests
Reassignment, requester resolution, role safety	Fig 7.7-7.8; staff E2E + API tests

Evidence key: figures are screenshots from the real local UI and a seeded _test database.
The only simulated response is Fig 6.4, deliberately intercepted to verify safe retry UI.
Claims without a matching figure are backed by named executable tests, not inferred from images.

Answer Part 7: Working IT Staff Ticket Detail UI (evidence)

Figure 7.1. Attachment continuity

The original Requester attachment remains downloadable in Staff detail.
Source: artifacts/lab-03/screenshots/staff-flow/states/10_attachment_continuity.png

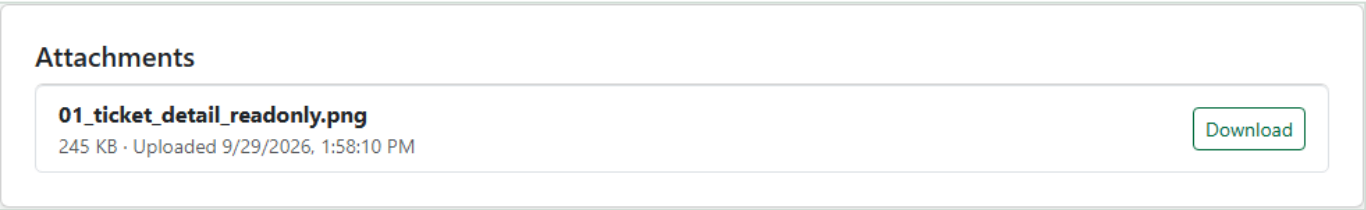
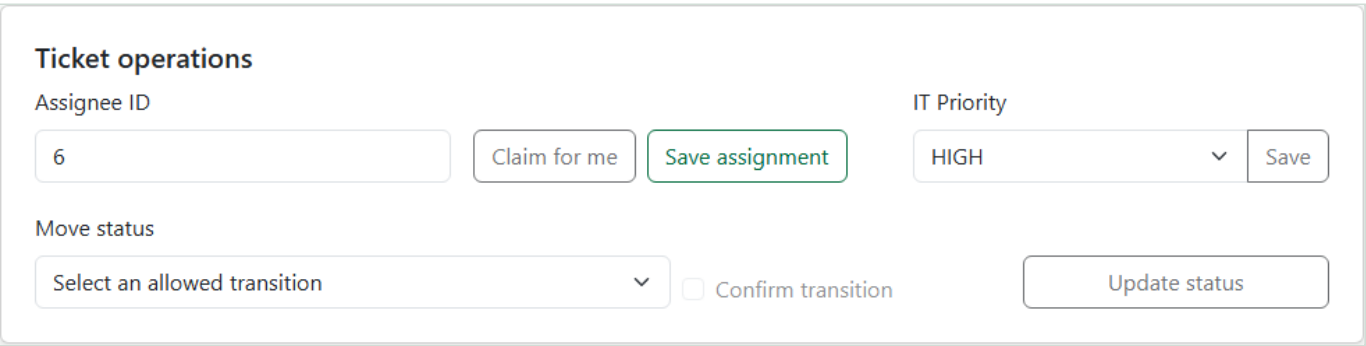


Figure 7.2. Claimed owner and operations

Claim for me is disabled after success; assignee ID is populated.
Source: artifacts/lab-03/screenshots/staff-flow/states/11_claimed_operation.png



Answer Part 7: Working IT Staff Ticket Detail UI (evidence)

Figure 7.3. Explicit transition confirmation

Attempting RESOLVED without confirmation gives a safe validation message.

Source: artifacts/lab-03/screenshots/staff-flow/states/07_detail_confirmation_required.png

TokTickIT

Ticket QueueTicket Detail

Alex Staff
IT_STAFFSign out

[← Back to queue](#)

IN_PROGRESS

Confirm this status transition before saving.

Ticket No.

TKT-2026-000006

REQUESTER

Sarah Johnson (sarah.johnson@example.com)

CATEGORY

Network

RELATED SYSTEM

VPN

CREATED

9/29/2026, 1:58:10 PM

UPDATED

9/29/2026, 1:58:14 PM

URGENT

Staff queue E2E regression

Verify that IT Staff can find and open a shared ticket.

Ticket operations

Assignee ID

7

Claim for me

Save assignment

IT Priority

URGENT

Save

Move status

RESOLVED (confirmation required)

Confirm transition

Update status

Attachments

01_ticket_detail_readonly.png

245 KB · Uploaded 9/29/2026, 1:58:10 PM

Download

Public comments

No public comments yet.

Add a public comment

Post public comment

Internal notes

Staff only

No internal notes yet.

Add an internal note

Add internal note

Answer Part 7: Working IT Staff Ticket Detail UI (evidence)

Figure 7.4. Resolved and urgent

The confirmed transition reaches RESOLVED; IT Priority is URGENT.

Source: artifacts/lab-03/screenshots/staff-flow/states/08_detail_resolved.png

TokTickIT

Ticket QueueTicket Detail

Alex StaffIT_STAFFSign out

[← Back to queue](#)

RESOLVED

Ticket No.
TKT-2026-000006

URGENT

REQUESTER
Sarah Johnson (sarah.johnson@example.com)

CATEGORY
Network

RELATED SYSTEM
VPN

CREATED
9/29/2026, 1:58:10 PM

UPDATED
9/29/2026, 1:58:15 PM

Staff queue E2E regression

Verify that IT Staff can find and open a shared ticket.

Ticket operations

Assignee ID

7

Claim for me

Save assignment

IT Priority

URGENT

Save

Move status

Select an allowed transition

Confirm transition

Update status

Attachments

01_ticket_detail_readonly.png

245 KB · Uploaded 9/29/2026, 1:58:10 PM

Download

Public comments

No public comments yet.

Add a public comment

Post public comment

Internal notes

Staff only

No internal notes yet.

Add an internal note

Add internal note

Answer Part 7: Working IT Staff Ticket Detail UI (evidence)

Figure 7.5. Public comment

A persisted public update is visible with author and timestamp.
Source: artifacts/lab-03/screenshots/staff-flow/states/14_public_comment.png

Public comments

Alex Staff · 9/29/2026, 1:58:15 PM

Public E2E evidence: requester can read this update.

Add a public comment

Post public comment

Figure 7.6. Internal note

The separate Staff only panel shows the persisted diagnostic note.
Source: artifacts/lab-03/screenshots/staff-flow/states/15_internal_note.png

Internal notes

Staff only

Alex Staff · 9/29/2026, 1:58:15 PM

Internal E2E evidence: staff-only diagnostic note.

Add an internal note

Add internal note

Answer Part 7: Working IT Staff Ticket Detail UI (evidence)

Figure 7.7. Reassigned to another IT Staff user

Assignment to Casey Staff is asserted against the real queue API and shown in Fig 6.7.

Source: artifacts/lab-03/screenshots/staff-flow/states/16_reassigned_operation.png

Ticket operations

Assignee ID

7

Claim for me

Save assignment

IT Priority

HIGH

▼

Save

Move status

Select an allowed transition

▼

☐ Confirm transition

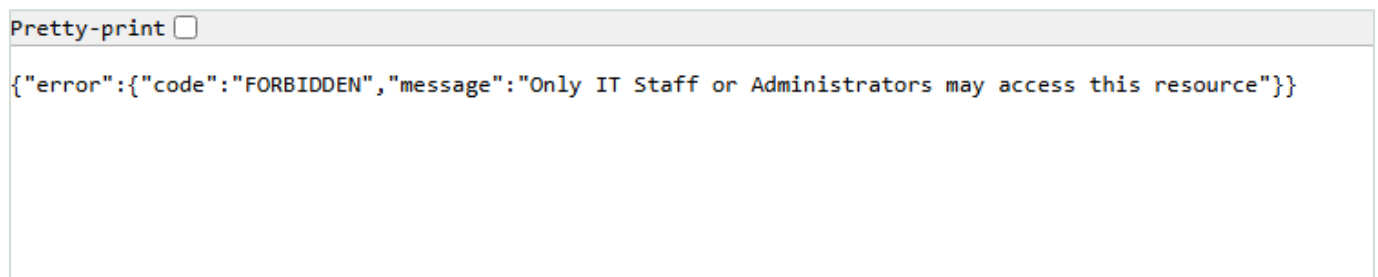
Update status

Answer Part 7: Working IT Staff Ticket Detail UI (evidence)

Figure 7.8. Requester denied Staff queue access

Requester GET /api/staff/tickets: actual HTTP 403 JSON response.

Source: artifacts/lab-03/screenshots/staff-flow/states/19_requester_staff_403_response.png



Magnified view of the unaltered browser response; Playwright also asserts HTTP status 403.

Answer Part 8: Working Administrator User Management UI

The Administrator journey uses real user records. Search and role filters precede create, edit, deactivate, and reset. A rejected self-deactivation and duplicate-email submission show server-enforced safeguards. Password field contents are masked in all captures.

Rubric / state	Evidence and provenance
List, search, role filter	Fig 8.1-8.3; admin UI/API tests
Create with role and initial password	Fig 8.4-8.5; admin E2E
Edit email/role/name and deactivate	Fig 8.6-8.7; admin E2E
Reset and next-login password gate	Fig 8.8 and 8.11; admin E2E
Self/last-active-admin protection	Fig 8.9; users-admin.api.test.ts
Duplicate email and non-admin denial	Fig 8.10 and 8.13; admin/authorization API tests

Evidence key: figures are screenshots from the real local UI and a seeded _test database.
The only simulated response is Fig 6.4, deliberately intercepted to verify safe retry UI.
Claims without a matching figure are backed by named executable tests, not inferred from images.

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.1. User list with active states

Live Administrator view shows display name, email, role, state and actions.

Source: artifacts/lab-03/screenshots/user-management/states/01_user_list.png

TokTickIT

User ManagementTicket Queue

TokTickIT Administrator
ADMINSign out

User Management

Manage roles and account activation without exposing credentials.

ADMIN

Search users

Role

All roles

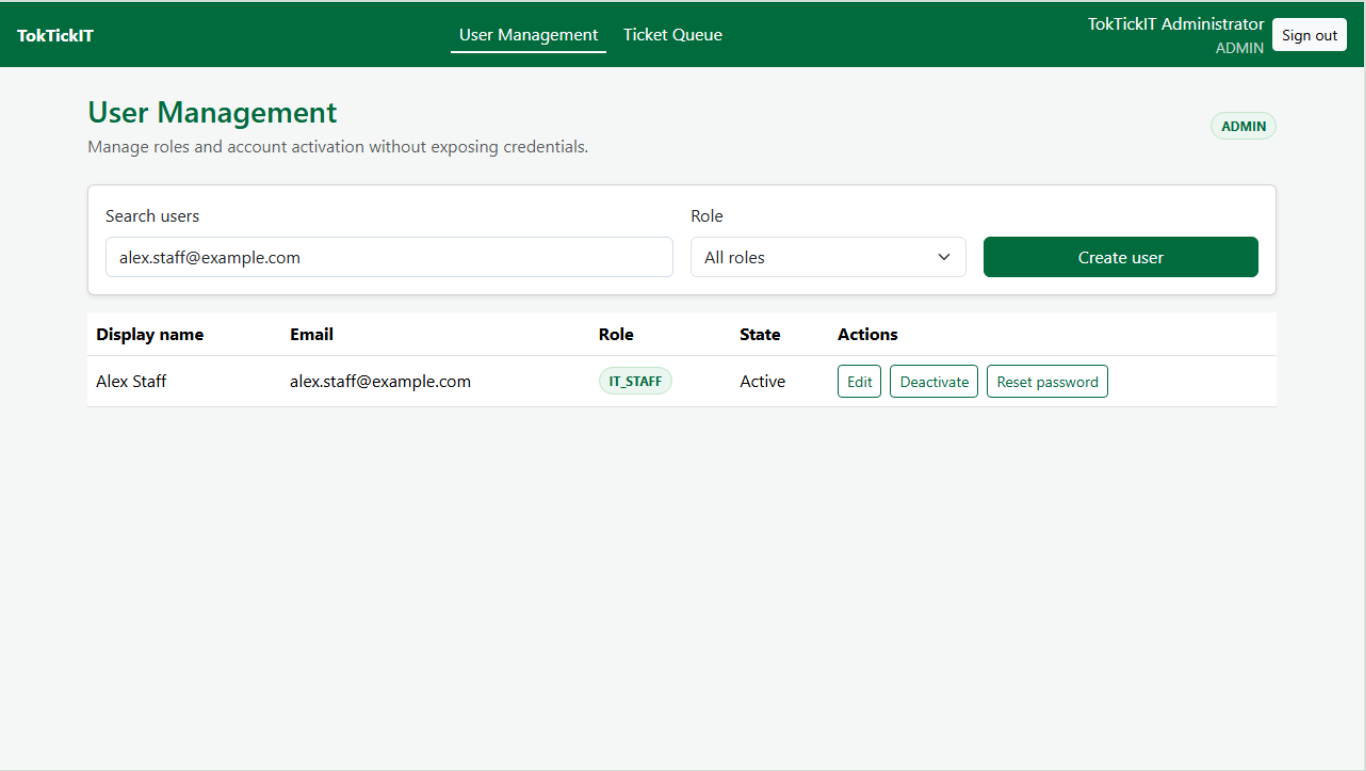
Create user

Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
David Lee	david.lee@example.com	REQUESTER	Active	EditDeactivateReset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	EditActivateReset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active	EditDeactivateReset password
Michael Brown	michael.brown@example.com	REQUESTER	Active	EditDeactivateReset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active	EditDeactivateReset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	EditDeactivateReset password

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.2. Search by email

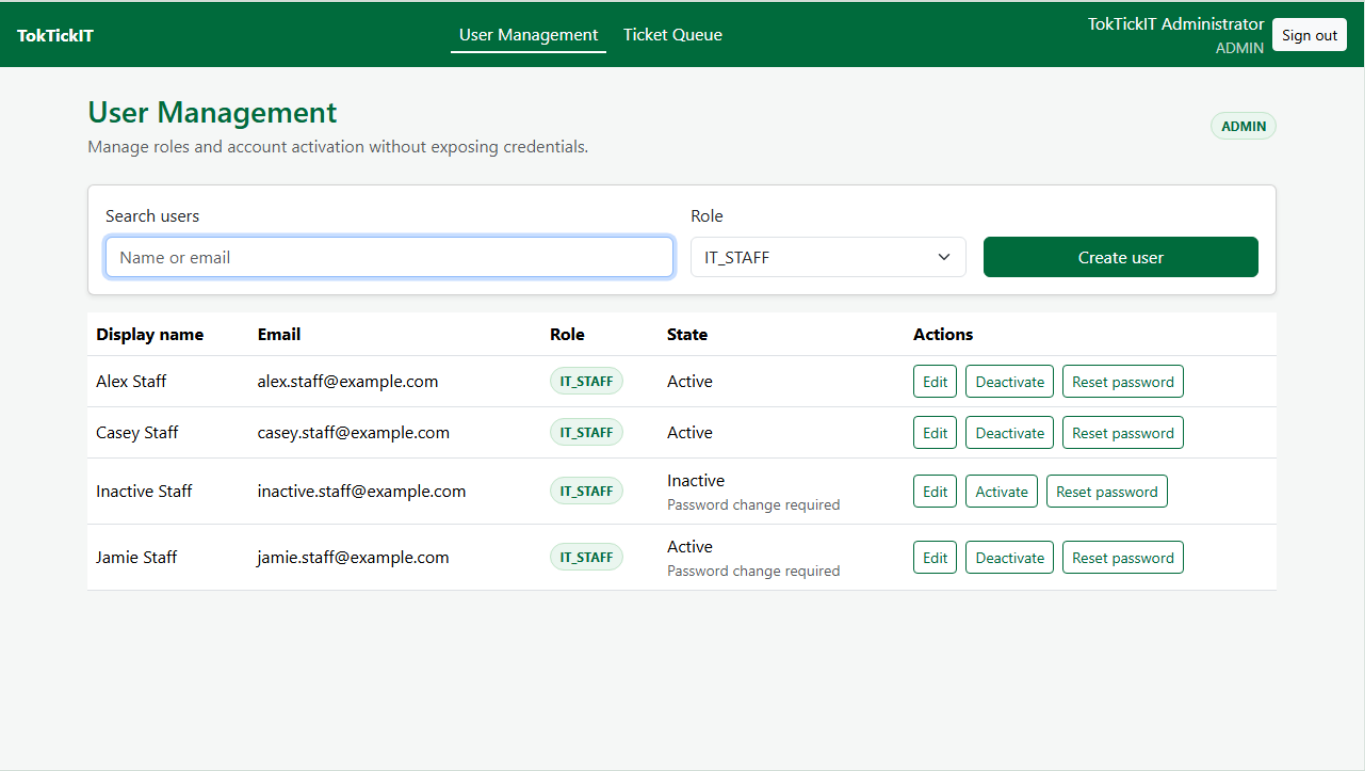
Search narrows the live list to the seeded IT Staff account.
Source: artifacts/lab-03/screenshots/user-management/states/02_user_search.png



Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.3. Role filter

IT_STAFF role filter changes the displayed records.
Source: artifacts/lab-03/screenshots/user-management/states/03_user_role_filter.png



Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.4. Create user form

Role and required fields are filled; initial password remains masked.
Source: artifacts/lab-03/screenshots/user-management/states/05_create_filled.png

TokTickIT

User ManagementTicket Queue

TokTickIT AdministratorADMINSign out

User Management

ADMIN

Manage roles and account activation without exposing credentials.

Search users

Name or email

Role

All roles

Create user

Create user

Cancel

Email

e2e-admin-created@example.com

Display name

E2E Admin Created

Role

IT_STAFF

☒ Active account

Initial password

.....

12-128 characters; the user must change it on first login.

Create user

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.5. Create success

The new IT Staff account appears and requests first-login password change.

Source: artifacts/lab-03/screenshots/user-management/states/06_created_success.png

TokTickIT

User ManagementTicket Queue

TokTickIT Administrator
ADMINSign out

User Management

ADMIN

Manage roles and account activation without exposing credentials.

Created E2E Admin Created.

Search users

Role

All roles

▼

Create user

Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
David Lee	david.lee@example.com	REQUESTER	Active	EditDeactivateReset password
E2E Admin Created	e2e-admin-created@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	EditActivateReset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active	EditDeactivateReset password
Michael Brown	michael.brown@example.com	REQUESTER	Active	EditDeactivateReset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active	EditDeactivateReset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	EditDeactivateReset password

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.6. Edit account

The existing record is reopened to edit its email, display name and role.

Source: artifacts/lab-03/screenshots/user-management/states/07_edit_form.png

TokTickIT

User ManagementTicket Queue

TokTickIT Administrator
ADMIN

Sign out

User Management

ADMIN

Manage roles and account activation without exposing credentials.

Search users

Role

Name or email

All roles

Create user

Edit user

Cancel

Email

Display name

e2e-admin-updated@example.com

E2E Admin Updated

Role

REQUESTER

Active account

Save changes

Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
David Lee	david.lee@example.com	REQUESTER	Active	EditDeactivateReset password
E2E Admin Created	e2e-admin-created@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	EditActivateReset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active	EditDeactivateReset password
Michael Brown	michael.brown@example.com	REQUESTER	Active	EditDeactivateReset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active	EditDeactivateReset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	EditDeactivateReset password

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.7. Deactivated account

State changes to Inactive without deleting historical records.

Source: artifacts/lab-03/screenshots/user-management/states/09_deactivated.png

TokTickIT

User ManagementTicket Queue

TokTickIT AdministratorADMINSign out

User Management

Manage roles and account activation without exposing credentials.

ADMIN

E2E Admin Updated is now inactive.

Search users

Role

All roles

▼

Create user

Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
David Lee	david.lee@example.com	REQUESTER	Active	EditDeactivateReset password
E2E Admin Updated	e2e-admin-updated@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	EditActivateReset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active	EditDeactivateReset password
Michael Brown	michael.brown@example.com	REQUESTER	Active	EditDeactivateReset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active	EditDeactivateReset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	EditDeactivateReset password

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.8. Initial-password reset

A safe success banner confirms reset; no password is printed.
Source: artifacts/lab-03/screenshots/user-management/states/11_reset_success.png

TokTickIT

User ManagementTicket Queue

TokTickIT Administrator
ADMINSign out

User Management

ADMIN

Manage roles and account activation without exposing credentials.

Reset the initial password for E2E Admin Updated.

Search users

Role

All roles

▼

Create user

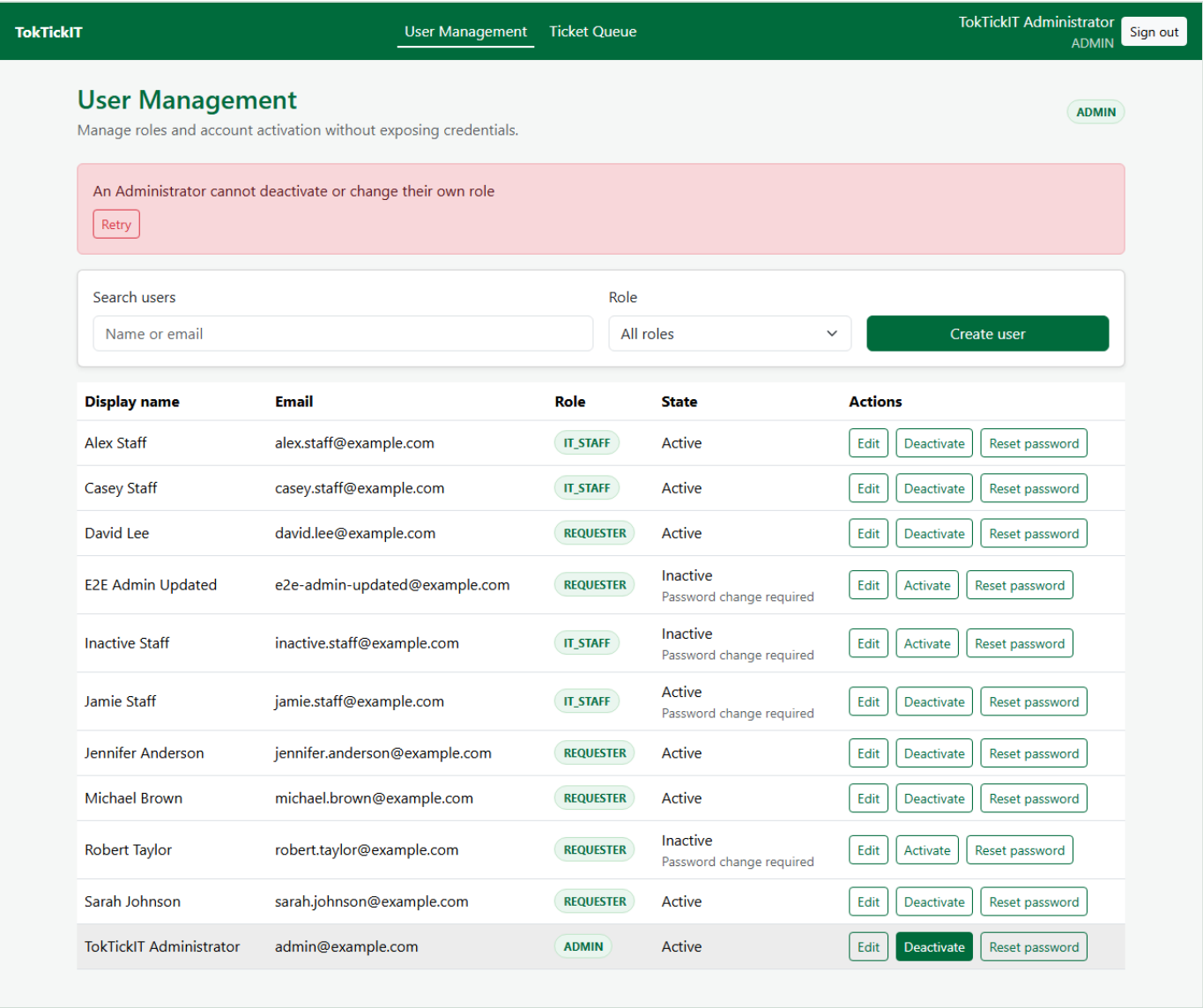
Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
David Lee	david.lee@example.com	REQUESTER	Active	EditDeactivateReset password
E2E Admin Updated	e2e-admin-updated@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	EditActivateReset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active	EditDeactivateReset password
Michael Brown	michael.brown@example.com	REQUESTER	Active	EditDeactivateReset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active	EditDeactivateReset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	EditDeactivateReset password

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.9. Self-deactivation rejected

The backend refuses deactivation of the current Administrator.

Source: artifacts/lab-03/screenshots/user-management/states/12_self_deactivation_rejected.png

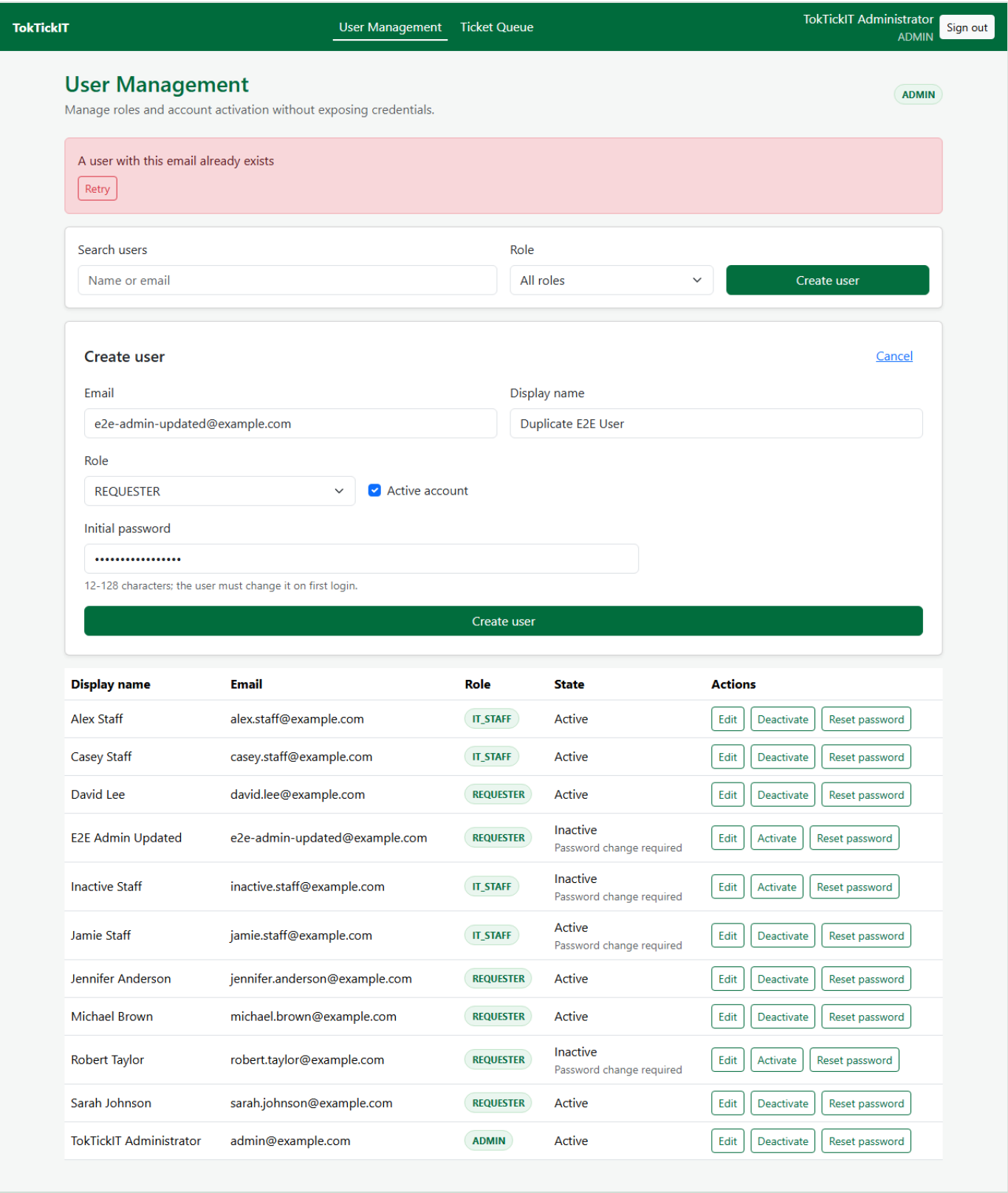


Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.10. Duplicate email rejected

Existing email is rejected with safe feedback; no duplicate is created.

Source: artifacts/lab-03/screenshots/user-management/states/13_duplicate_email_rejected.png



Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.11. Reset requires password change on next login

After reset, the real account signs in and reaches Change your password instead of its workspace.

Source: artifacts/lab-03/screenshots/user-management/states/14_reset_requires_change_on_next_login.png

TokTickIT

Change your password

Your account requires a password change before you can access tickets.

Current password

New password

Use 12-128 characters.

Confirm new password

[Update password](#) [Sign out](#)

Signed in as e2e-admin-updated@example.com

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.12. Invalid create input blocked

Native email/password validation prevents the invalid form from being submitted.
Source: artifacts/lab-03/screenshots/user-management/states/04_invalid_input_blocked.png

TokTickIT

User ManagementTicket Queue

TokTickIT Administrator
ADMINSign out

User Management

ADMIN

Manage roles and account activation without exposing credentials.

Search users

Role

All roles

Create user

Create user

Cancel

Email

not-an-email

Display name

Invalid Evidence User

Role

REQUESTER

☒ Active account

Initial password

.....

12-128 characters; the user must change it on first login.

Create user

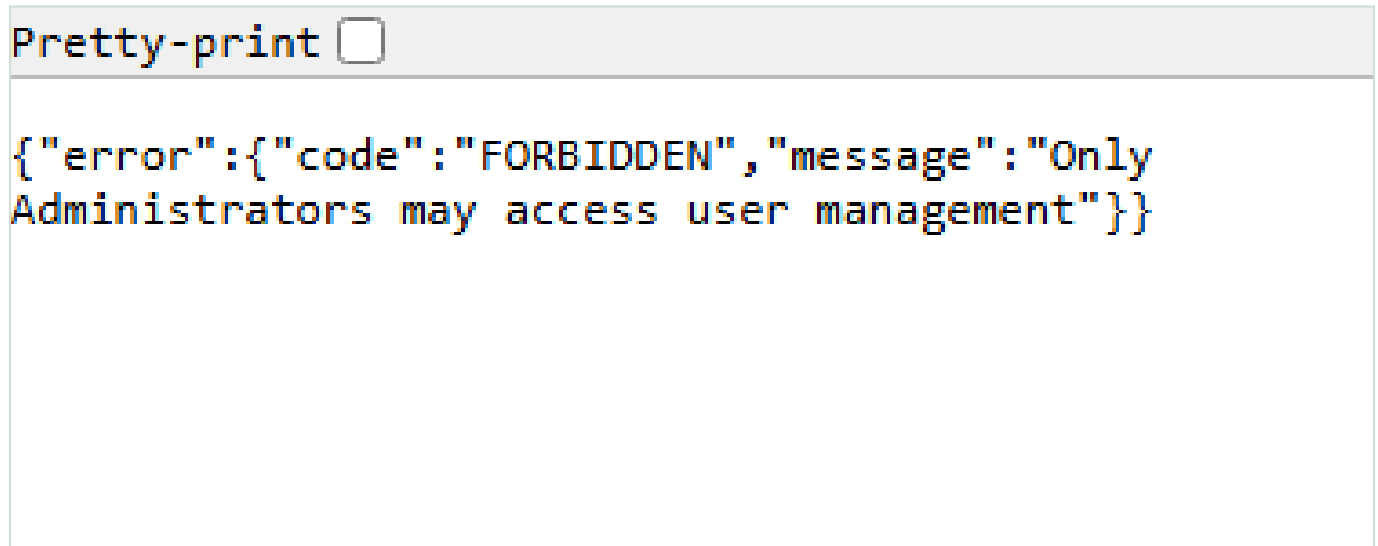
Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active	EditDeactivateReset password
David Lee	david.lee@example.com	REQUESTER	Active	EditDeactivateReset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	EditActivateReset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	EditDeactivateReset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active	EditDeactivateReset password
Michael Brown	michael.brown@example.com	REQUESTER	Active	EditDeactivateReset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	EditActivateReset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active	EditDeactivateReset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	EditDeactivateReset password

Answer Part 8: Working Administrator User Management UI (evidence)

Figure 8.13. IT Staff denied Administrator access

IT Staff GET /api/admin/users: actual HTTP 403 JSON response.

Source: artifacts/lab-03/screenshots/staff-flow/states/20_staff_admin_403_response.png



Magnified view of the unaltered browser response; Playwright also asserts HTTP status 403.

Answer Part 9: Zen Green UI and Responsive Evidence

The four Lab 3 views below were captured from the running app in desktop, tablet and mobile Playwright projects against the dedicated test database. Figures 9.1-9.12 embed the original full-page screenshots; long mobile views also have magnified reading pages.

View	Desktop	Tablet	Mobile
Authentication	9.1	9.2	9.3
Staff Queue	9.4	9.5	9.6
Staff Ticket Detail	9.7	9.8	9.9
User Management	9.10	9.11	9.12
Responsive and accessibility check			

Zen Green tokens, readable contrast, visible focus, accessible labels and keyboard actions are shared across roles. The E2E run asserts no page-level horizontal overflow at all 12 view/viewport combinations. Visual review of the 12 captured states found no clipped text or overlapping buttons. Queue sorting remains available in its mobile card layout.

Verification provenance: 29 September 2026 local feature-branch checkout; 13/13 Playwright tests passed. These additional evidence changes are not yet merged into main. The previously merged release is historical context, not proof that this PDF was submitted.

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Approved UI specification - rendered source (1)

Complete tracked source: docs/lab-03/ui-spec.md

Lab 3 UI Specification

Status: Approved contract (PR #40 merged into lab3-staging); finalized for the main release evidence.

Design foundation

Continue the Lab 2 Zen Green visual language: dark neutral surfaces, green success/accent states, readable contrast, consistent focus rings, shared buttons/inputs/tables, and no horizontal overflow. Reuse existing tokens and components rather than introducing a second visual system.

Breakpoints: desktop at 992px and above, tablet 768-991px, mobile below 768px. At every breakpoint content must reflow without clipping or overlap. Tables become stacked cards or scroll within the component only when required; the page itself must not overflow horizontally.

Application shell and navigation

- Unauthenticated users see Login only.
- Authenticated users see a role-specific navigation and the current display name/role.
- Requester navigation: Create Ticket, My Tickets.
- IT Staff navigation: Ticket Queue, Ticket Detail when selected.
- Administrator navigation: User Management plus Ticket Queue/Ticket Detail because the approved authorization matrix explicitly grants Admin Ticket operations; Requester views remain available only where the matrix permits them.
- Logout is always available. A must-change-password banner/gate takes priority over normal navigation.

Login screen

Fields: email and password, show/hide password control, submit button, and an inline error region. States: idle, submitting, invalid credentials, inactive account after credential verification, network failure with retry, and success redirect. Keyboard focus order and visible focus styles are required. At mobile width the form is single-column and full-width.

Change-password screen

Fields: current password, new password, confirm new password, password-policy hint, and submit. States: idle, validation error, submitting, incorrect current password, server failure, and success. The route cannot be bypassed while `mustChangePassword` is true.

Requester regression screens

Create Ticket and My Tickets retain Lab 2 behavior with authenticated identity. Ticket Detail remains read-only for ticket fields, adds public comments and a Problem appears resolved control, and keeps attachment upload/download/soft-remove ownership rules. Requesters never see internal notes, assignee controls, or staff-only statuses.

Required states include loading, empty/no-results, API failure with retry, validation, submitting, success, and inactive/deauthenticated session redirect.

IT Staff Ticket Queue

Provide a heading, search field, status, IT-priority, assignee, and category filters, sortable result columns/cards, page-size and page navigation controls, result count, and a responsive ticket list. Search, filter, sort, and pagination values must match the API contract, including clear invalid-query feedback. Each row/card shows ticket number, subject/summary, requester, status, IT priority, assignee, and updated time. States: loading skeleton, empty queue, no-results, invalid-query, API error/retry, and populated queue. Selecting a ticket opens Staff Ticket Detail.

IT Staff Ticket Detail

Show ticket identity, requester, metadata, current status, IT priority, assignee, claim/reassign controls, allowed status actions, public comments, and internal notes. Distinguish public comments and notes visually and semantically; show the author and creation time supplied by the backend. Disable or hide invalid transitions, but rely on server authorization for enforcement. Require confirmation for transitions marked in the matrix and show conflict/error feedback without losing unsent text.

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Approved UI specification - rendered source (2)

Administrator User Management

Show user list with search and optional role filter, plus create/edit form. Rows/cards show display name, email, role, active state, and must-change-password state. Creation and editing validate one permitted role, activation state, duplicate email, self-deactivation, and last-active-Admin safety. Actions: create, edit, activate/deactivate, and set initial password. States: loading, empty, no-results, validation, duplicate-email conflict, forbidden, server failure/retry, and success confirmation. Do not render password values or session information.

Accessibility and responsive acceptance

- All controls have accessible labels and keyboard operation.
- Error text is associated with its field and announced in a live region when appropriate.
- Focus remains visible after dialogs, mutations, and responsive layout changes.
- At desktop, tablet, and mobile widths there is no page-level horizontal overflow, clipped text, or overlapping controls.
- Screenshot evidence must cover authentication, staff queue, staff detail, and user management at representative desktop/tablet/mobile widths.

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Completed visual and accessibility checklist

Checked against the captured local UI states and the approved Lab 2/Lab 3 UI contracts.
A screenshot documents its visible state; behavior beyond the frame is attributed to named tests.

Check	Result and evidence
Zen Green and type	Checked - Approved color tokens, consistent typography and shared controls; Fig 9.1-9.12.
Role-aware navigation	Checked - Login shell and role routes; Part 5, Fig 6.1, 7.1, 8.1; auth E2E/API.
Badges and status	Checked - Queue/detail priority and status distinguishable; Fig 6.1, 7.2-7.4, 8.1.
Editable/read-only	Checked - Staff/Admin actions separated from requester read-only fields; Fig 7.2, 8.6; UI tests.
Validation and errors	Checked - Field errors, safe denial and retry placement; Part 5, Fig 6.3-6.4, 8.9-8.12.
Focus and keyboard	Checked - Focus styles and semantic labels checked in client source; no focus-state photo claimed.
Clipping and overlap	Checked - Visual review of the 12 captured viewport states: none observed.
Horizontal overflow	Checked - Playwright checks document width at all 12 view/viewport combinations.

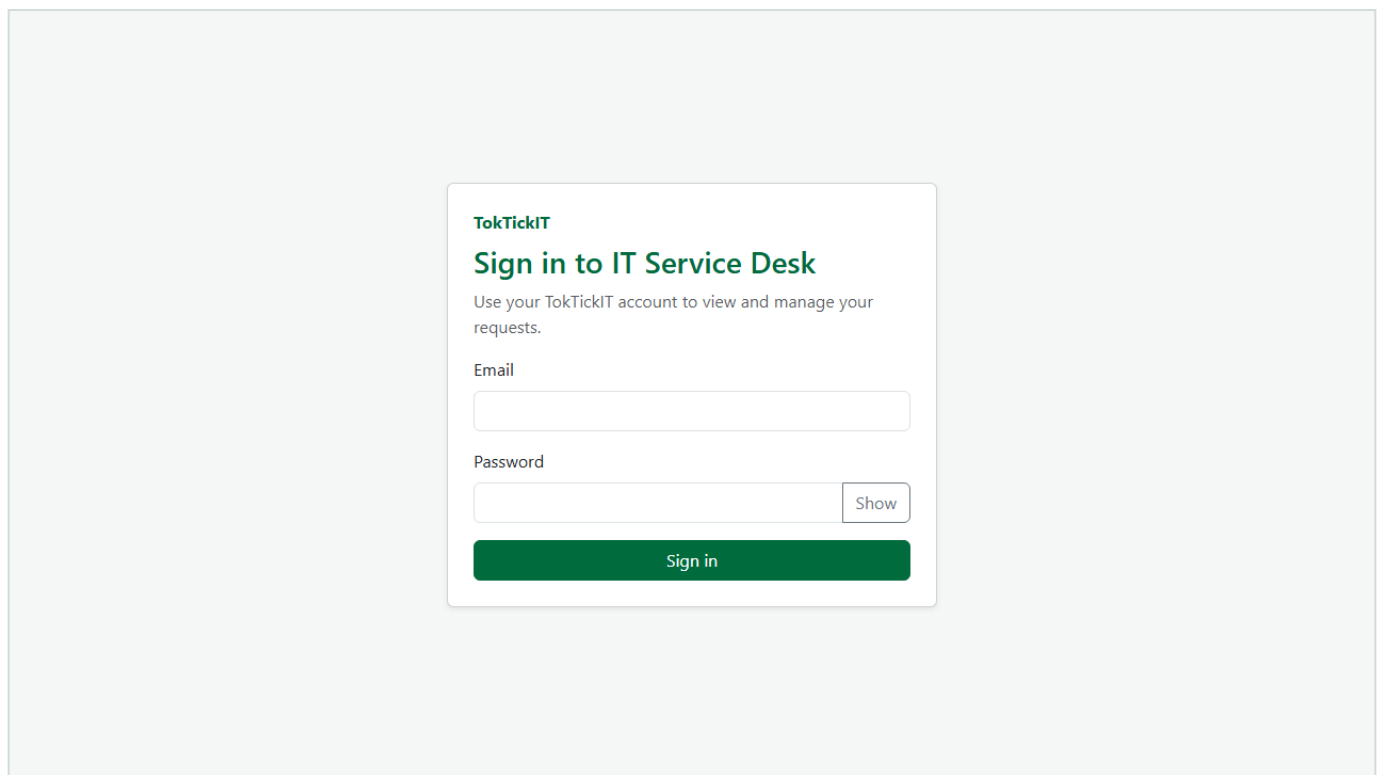
Source checklist: docs/lab-02/tests.md, section 4; acceptance: docs/lab-03/ui-spec.md.

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.1. Authentication — desktop

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: [artifacts/lab-03/screenshots/authentication/desktop.png](#)

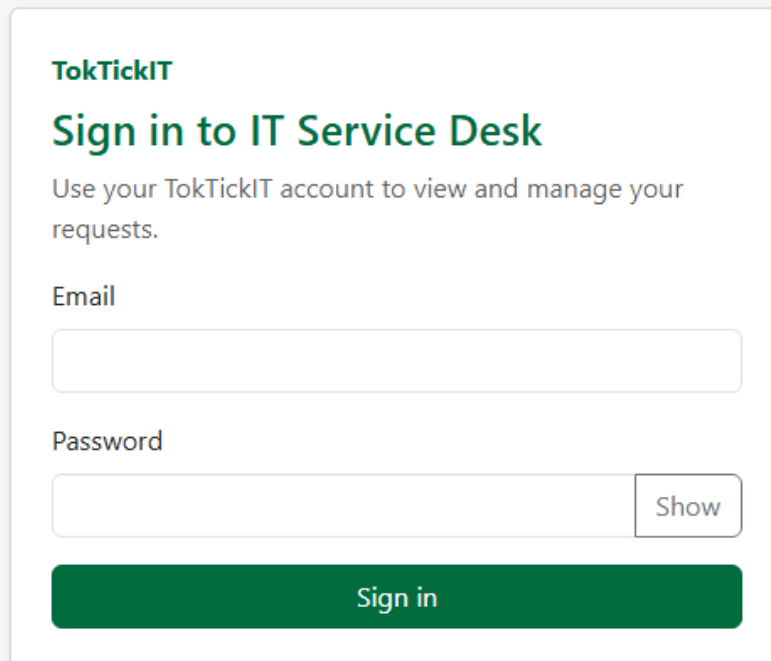


Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.2. Authentication — tablet

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/authentication/tablet.png



TokTickIT

Sign in to IT Service Desk

Use your TokTickIT account to view and manage your requests.

Email

Password

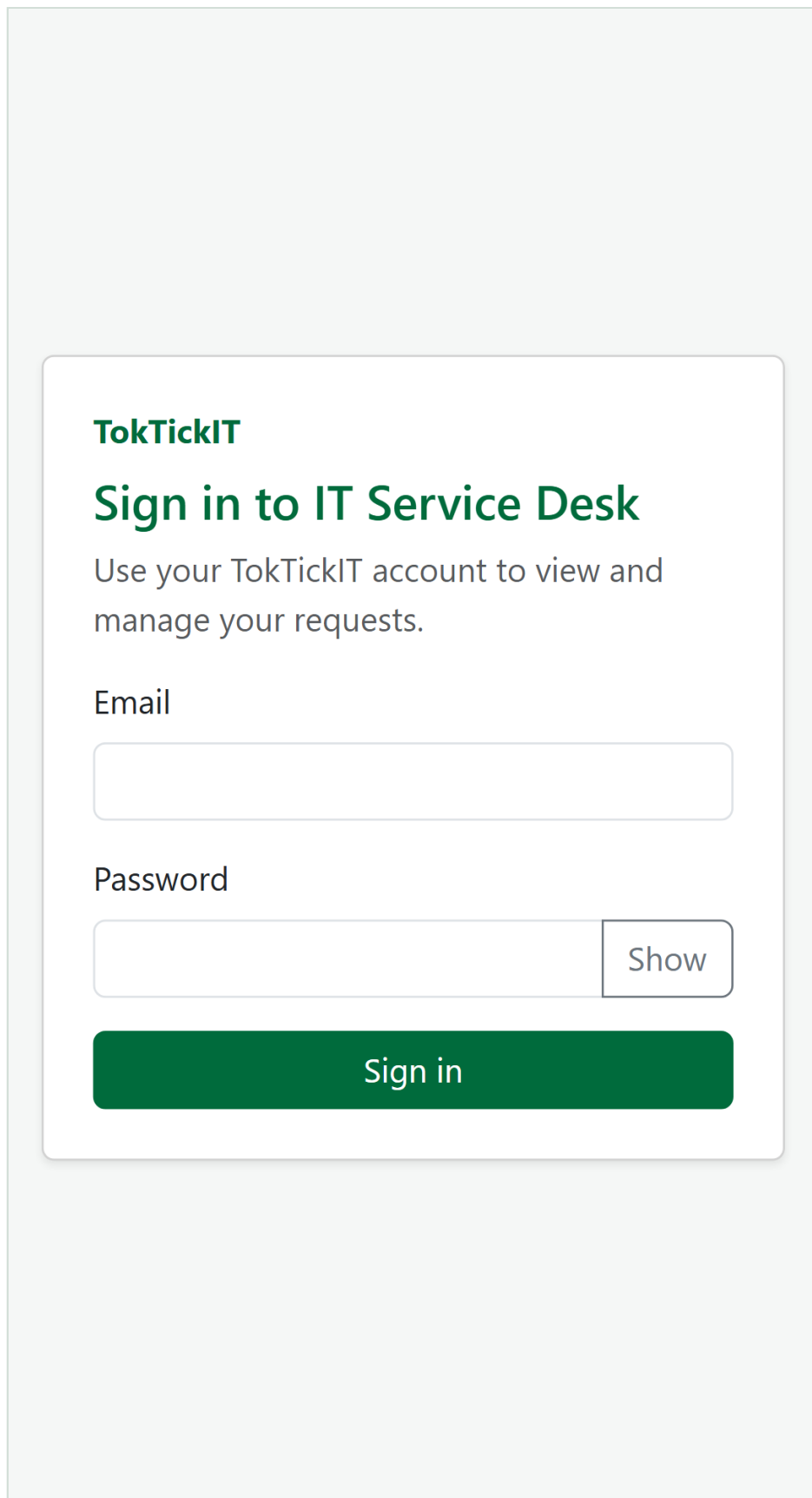
Sign in

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.3. Authentication — mobile

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/authentication/mobile.png

A mobile authentication screen for TokTickIT. The screen has a light gray background. In the center, there is a white rounded rectangle containing the login form. At the top of this rectangle is the TokTickIT logo in green. Below the logo is the title 'Sign in to IT Service Desk' in green. Underneath the title is a subtitle in gray: 'Use your TokTickIT account to view and manage your requests.' The form consists of two input fields: 'Email' and 'Password'. The 'Email' field is a simple white box with a light gray border. The 'Password' field is a white box with a light gray border, followed by a 'Show' button in a light gray box. Below these fields is a large green 'Sign in' button with white text.

TokTickIT

Sign in to IT Service Desk

Use your TokTickIT account to view and manage your requests.

Email

Password

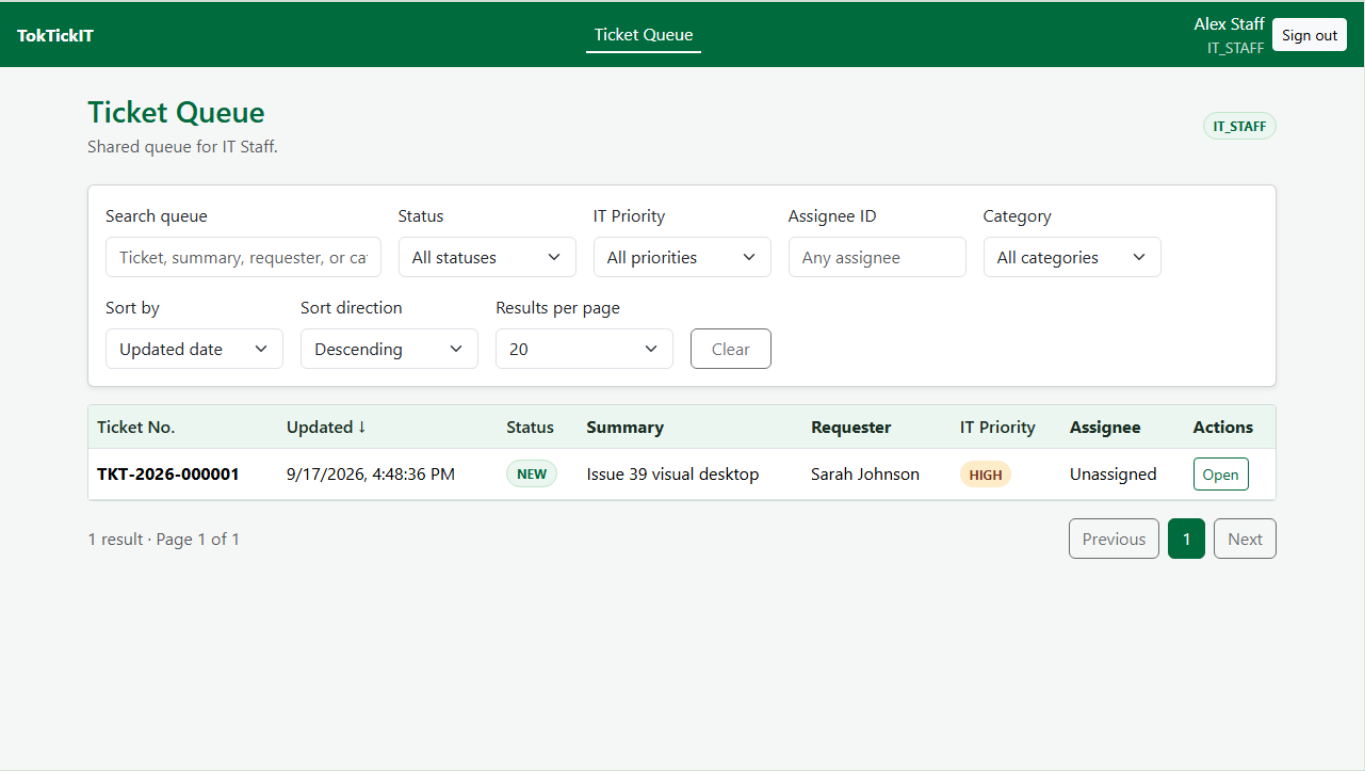
Sign in

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.4. Staff Queue — desktop

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/staff-queue/desktop.png

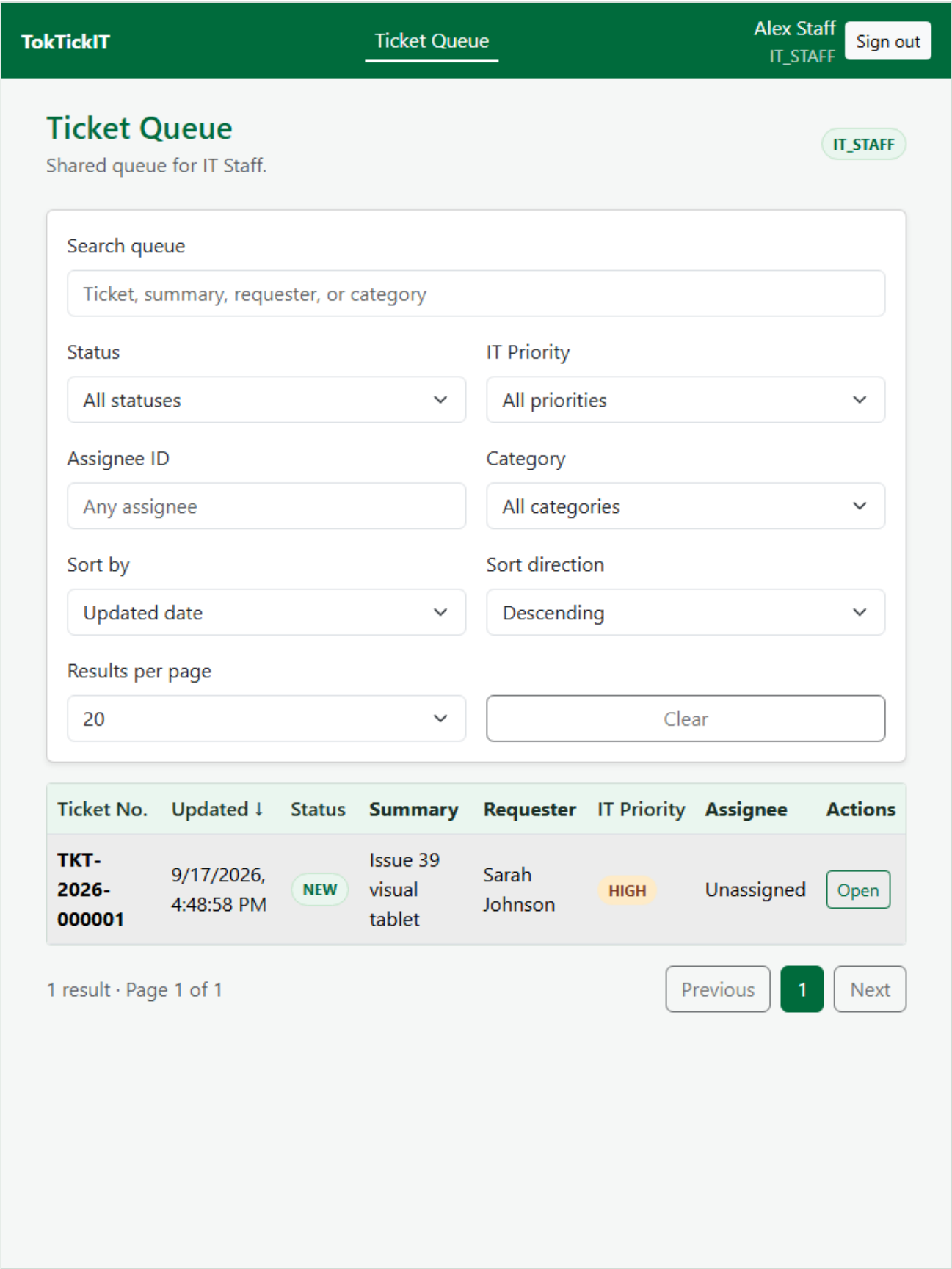


Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.5. Staff Queue — tablet

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/staff-queue/tablet.png



Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.6. Staff Queue — mobile

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/staff-queue/mobile.png

TokTickITTicket QueueAlex StaffIT_STAFFSign out

Ticket QueueIT_STAFF

Shared queue for IT Staff.

Search queue

Ticket, summary, requester, or category

Status

All statuses

IT Priority

All priorities

Assignee ID

Any assignee

Category

All categories

Sort by

Updated date

Sort direction

Descending

Results per page

20

Clear

TKT-2026-000002NEW

Issue 39 visual mobile

Requester: Sarah Johnson

HIGHUnassigned

Updated 9/17/2026, 4:49:14 PM

Open ticket

TKT-2026-000001NEW

Issue 39 visual tablet

Requester: Sarah Johnson

HIGHUnassigned

Updated 9/17/2026, 4:48:58 PM

Open ticket

2 results · Page 1 of 1

Previous1Next

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.6 detail 1/2 — Staff Queue mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

TokTickIT

Ticket Queue

Alex Staff
IT_STAFF

Sign out

Ticket Queue

IT_STAFF

Shared queue for IT Staff.

Search queue

Ticket, summary, requester, or category

Status

All statuses

IT Priority

All priorities

Assignee ID

Any assignee

Category

All categories

Sort by

Updated date

Sort direction

Descending

Results per page

20

Clear

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.6 detail 2/2 — Staff Queue mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

TKT-2026-000002

NEW

Issue 39 visual mobile

Requester: Sarah Johnson

HIGH Unassigned

Updated 9/17/2026, 4:49:14 PM

Open ticket

TKT-2026-000001

NEW

Issue 39 visual tablet

Requester: Sarah Johnson

HIGH Unassigned

Updated 9/17/2026, 4:48:58 PM

Open ticket

2 results · Page 1 of 1

Previous

1

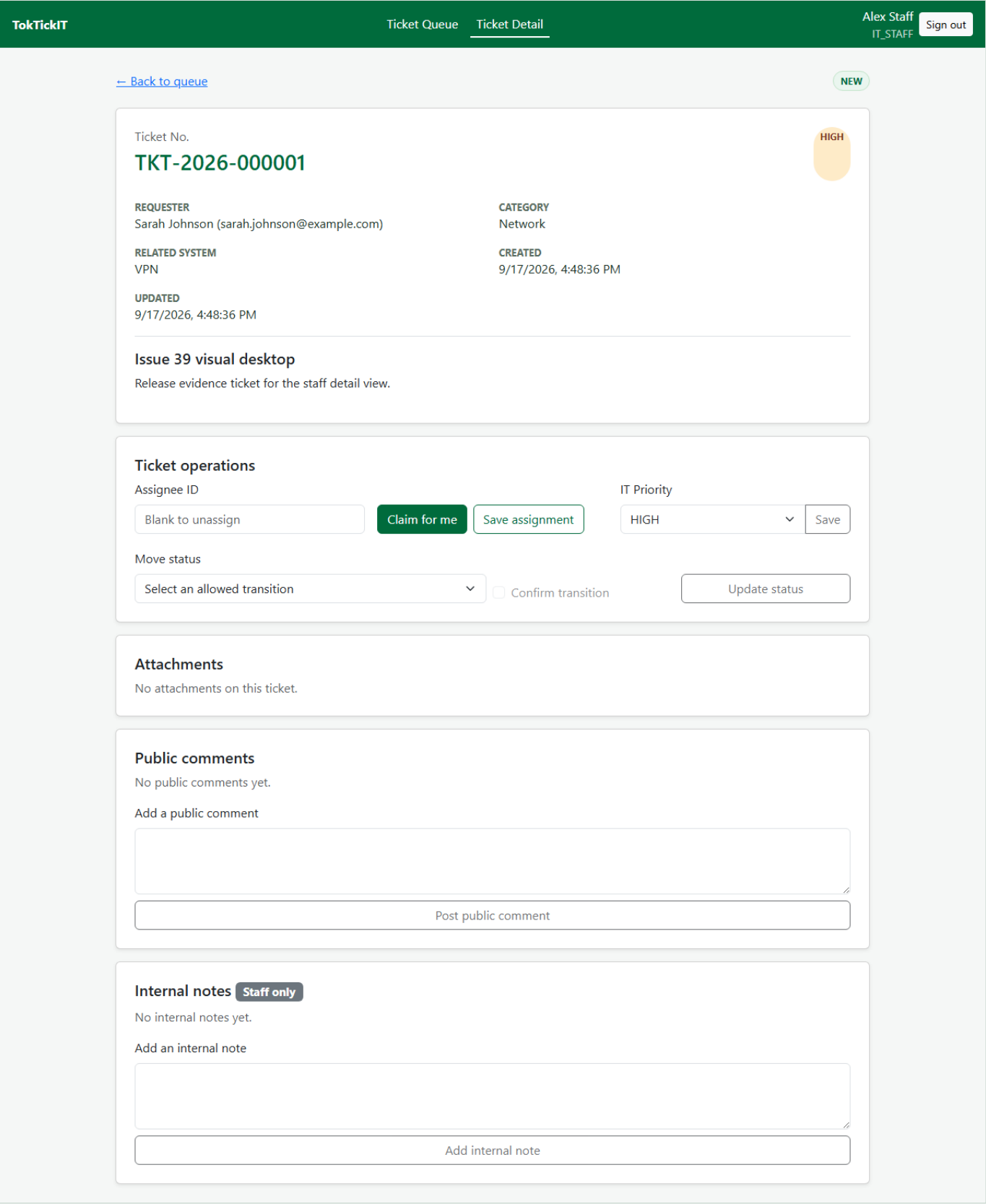
Next

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.7. Staff Ticket Detail — desktop

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/staff-ticket-detail/desktop.png



Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.8. Staff Ticket Detail — tablet

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/staff-ticket-detail/tablet.png

TokTickIT

Ticket QueueTicket Detail

Alex Staff
IT_STAFF

Sign out

[← Back to queue](#)

NEW

Ticket No.

TKT-2026-000001

HIGH

REQUESTER

Sarah Johnson
(sarah.johnson@example.com)

CATEGORY

Network

RELATED SYSTEM

VPN

CREATED

9/17/2026, 4:48:58 PM

UPDATED

9/17/2026, 4:48:58 PM

Issue 39 visual tablet

Release evidence ticket for the staff detail view.

Ticket operations

Assignee ID

Blank to unassign

Claim for me

Save assignment

IT Priority

HIGH

▼

Save

Move status

Select an allowed transition

▼

☐ Confirm transition

Update status

Attachments

No attachments on this ticket.

Public comments

No public comments yet.

Add a public comment

Post public comment

Internal notes

Staff only

No internal notes yet.

Add an internal note

Add internal note

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.9. Staff Ticket Detail — mobile

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/staff-ticket-detail/mobile.png

TokTickITTicket QueueTicket Detail

Alex StaffIT_STAFFSign out

[← Back to queue](#)

NEW

Ticket No.
TKT-2026-000002

HIGH

REQUESTER
Sarah Johnson
(sarah.johnson@example.com)

CATEGORY
Network

RELATED SYSTEM
VPN

CREATED
9/17/2026, 4:49:14 PM

UPDATED
9/17/2026, 4:49:14 PM

Issue 39 visual mobile
Release evidence ticket for the staff detail view.

Ticket operations

Assignee ID

Blank to unassign

Claim for me

Save assignment

IT Priority

HIGH

▼

Save

Move status

Select an allowed transition

▼

☐ Confirm transition

Update status

Attachments

No attachments on this ticket.

Public comments

No public comments yet.

Add a public comment

Post public comment

Internal notes

Staff only

No internal notes yet.

Add an internal note

Add internal note

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.9 detail 1/3 — Staff Ticket Detail mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

TokTickIT

Ticket Queue

Ticket Detail

Alex Staff
IT_STAFF

Sign out

[← Back to queue](#)

NEW

Ticket No.

TKT-2026-000002

HIGH

REQUESTER

Sarah Johnson
(sarah.johnson@example.com)

CATEGORY

Network

RELATED SYSTEM

VPN

CREATED

9/17/2026, 4:49:14 PM

UPDATED

9/17/2026, 4:49:14 PM

Issue 39 visual mobile

Release evidence ticket for the staff detail view.

Ticket operations

Assignee ID

Blank to unassign

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.9 detail 2/3 — Staff Ticket Detail mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

Claim for meSave assignment

IT Priority

HIGH

Save

Move status

Select an allowed transition

☐ Confirm transition

Update status

Attachments

No attachments on this ticket.

Public comments

No public comments yet.

Add a public comment

Post public comment

Internal notes

Staff only

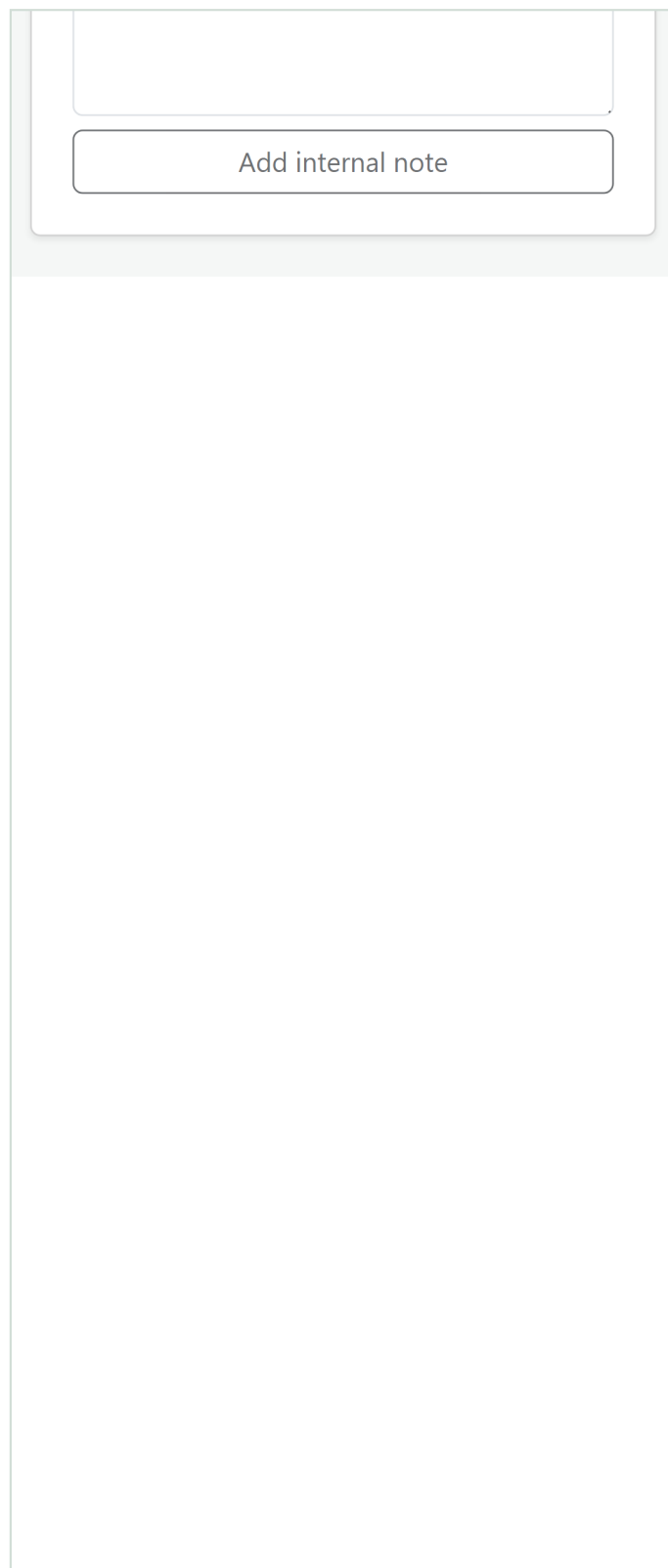
No internal notes yet.

Add an internal note

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.9 detail 3/3 — Staff Ticket Detail mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

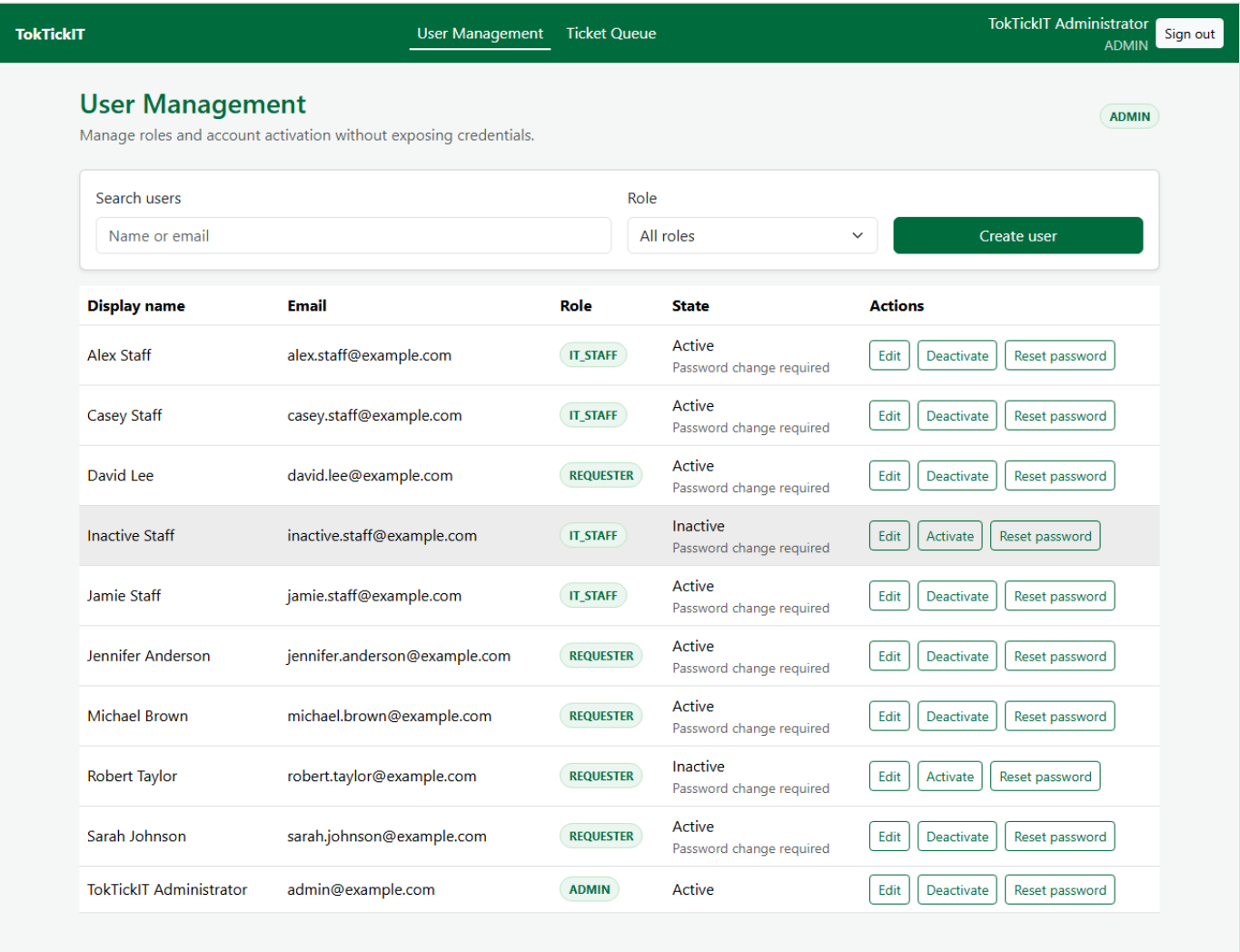


Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.10. User Management — desktop

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/user-management/desktop.png



Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.11. User Management — tablet

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/user-management/tablet.png

TokTickIT

User Management

Ticket Queue

TokTickIT Administrator
ADMIN

Sign out

User Management

Manage roles and account activation without exposing credentials.

ADMIN

Search users

Role

Name or email

All roles

Create user

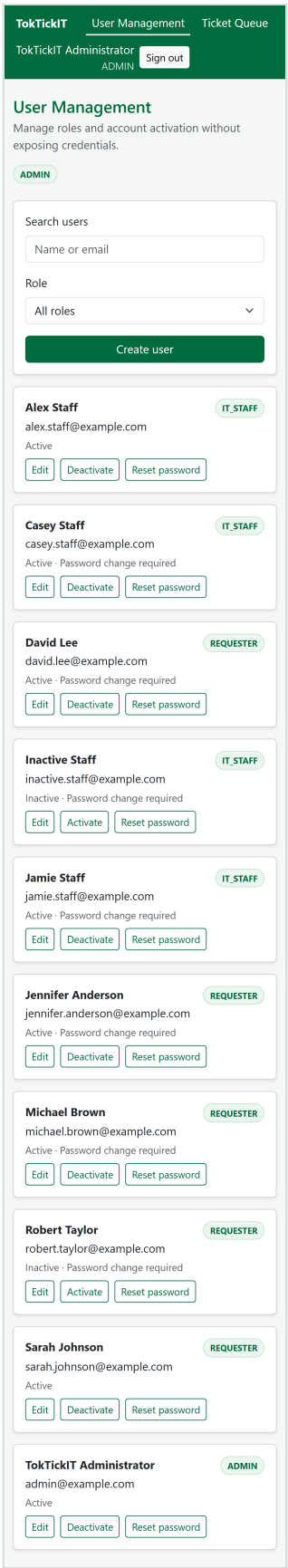
Display name	Email	Role	State	Actions
Alex Staff	alex.staff@example.com	IT_STAFF	Active Password change required	Edit Deactivate Reset password
Casey Staff	casey.staff@example.com	IT_STAFF	Active Password change required	Edit Deactivate Reset password
David Lee	david.lee@example.com	REQUESTER	Active Password change required	Edit Deactivate Reset password
Inactive Staff	inactive.staff@example.com	IT_STAFF	Inactive Password change required	Edit Activate Reset password
Jamie Staff	jamie.staff@example.com	IT_STAFF	Active Password change required	Edit Deactivate Reset password
Jennifer Anderson	jennifer.anderson@example.com	REQUESTER	Active Password change required	Edit Deactivate Reset password
Michael Brown	michael.brown@example.com	REQUESTER	Active Password change required	Edit Deactivate Reset password
Robert Taylor	robert.taylor@example.com	REQUESTER	Inactive Password change required	Edit Activate Reset password
Sarah Johnson	sarah.johnson@example.com	REQUESTER	Active Password change required	Edit Deactivate Reset password
TokTickIT Administrator	admin@example.com	ADMIN	Active	Edit Deactivate Reset password

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.12. User Management — mobile

Full-page screenshot from the real Playwright viewport project; original PNG is embedded.

Source: artifacts/lab-03/screenshots/user-management/mobile.png



Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.12 detail 1/3 — User Management mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

TokTickITUser ManagementTicket Queue

TokTickIT AdministratorADMINSign out

User Management

Manage roles and account activation without exposing credentials.

ADMIN

Search users

Role

All roles

▼

Create user

Alex StaffIT_STAFF

alex.staff@example.com

Active

EditDeactivateReset password

Casey StaffIT_STAFF

casey.staff@example.com

Active · Password change required

EditDeactivateReset password

David LeeREQUESTER

david.lee@example.com

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.12 detail 2/3 — User Management mobile

Magnified section of the same original full-page screenshot; no UI content was altered.

Active · Password change required

EditDeactivateReset password

Inactive Staff IT_STAFF

inactive.staff@example.com

Inactive · Password change required

EditActivateReset password

Jamie Staff IT_STAFF

jamie.staff@example.com

Active · Password change required

EditDeactivateReset password

Jennifer Anderson REQUESTER

jennifer.anderson@example.com

Active · Password change required

EditDeactivateReset password

Michael Brown REQUESTER

michael.brown@example.com

Active · Password change required

EditDeactivateReset password

Robert Taylor REQUESTER

robert.taylor@example.com

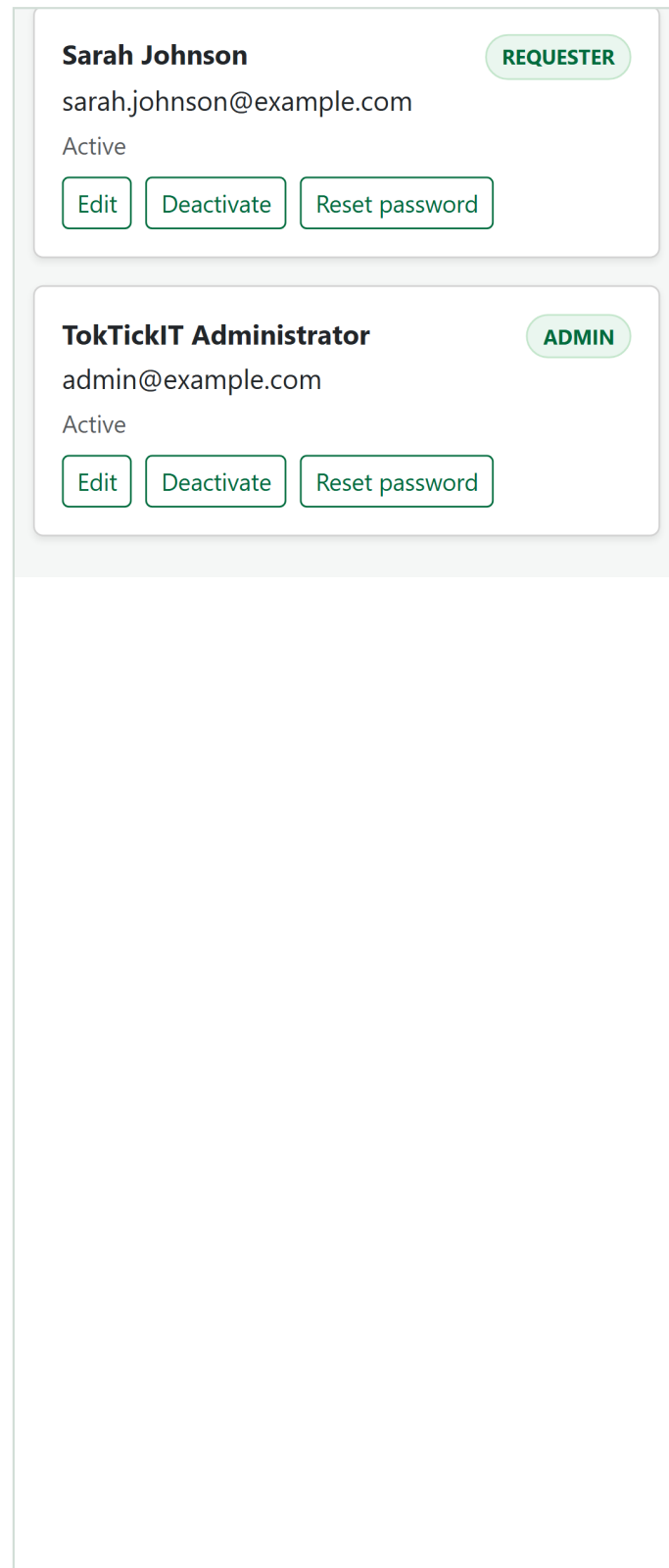
Inactive · Password change required

EditActivateReset password

Answer Part 9: Zen Green UI and Responsive Evidence (evidence)

Figure 9.12 detail 3/3 — User Management mobile

Magnified section of the same original full-page screenshot; no UI content was altered.



LAB 3 : Final Evidence Addendum

TokTickIT Authenticated IT Ticketing System — Lab 2 template continuation

The report retains the Lab 2 submission layout: centered title, Answer Parts, gray evidence tables and yellow status callouts. This addendum keeps that visual language while adding contract crosswalks and readable local verification records.

Release provenance

Implementation release: **main @ 92fac36**, merged by PR #46. Documentation follow-up: **e7998d3**, PR #47. Expanded UI evidence and this PDF are prepared on **feature/lab3-final-evidence** and must not be treated as already merged into main.

The report uses vector ReportLab text and tables throughout the template pages and addendum. Screenshot evidence is embedded at its source PNG resolution; it is not first rasterized into a low-resolution page image.

Latest local verification record

The following values come from commands actually run on 29 September 2026 in the feature/lab3-final-evidence checkout, after the additional screenshots and E2E assertions were added. This working-tree evidence is not represented as already merged into main.

Gate	Observed result	Source
Server npm test	16 files / 92 tests passed	artifacts/lab-03/verification/server-test.txt
Client npm test	15 files / 50 tests passed	artifacts/lab-03/verification/client-test.txt
Server and client builds	Both commands exited 0	artifacts/lab-03/verification/server-build.txt and client-build.txt
Playwright	13 passed, 0 failed, 0 skipped, 0 flaky; desktop/tablet/mobile	artifacts/lab-02/e2e-results.json
Migration and seed	5 migrations found; none pending; npm seed completed twice with equal category/system/requester totals	artifacts/lab-03/verification/migration-seed-final.txt

The E2E run used a guarded database whose name ends in `_test`. Playwright reset and seeded that database before the run; these were not production records. Queue pagination uses 21 Requester-created test tickets. Figure 6.4 alone intercepts an API response to test retry behavior and is labeled simulated.

A previous sandbox-only seed attempt failed while Node queried Windows user information; an elevated retry of the unmodified npm seed command then passed twice. The clean final migration/seed log is linked above. No failed attempt is counted as a pass.

Contract completeness crosswalk

Required contract element	Evidence in approved source	Release check
Sprint goal, stakeholder request, and scope/exclusions	specification.md §§1–3	Scope is explicit before implementation
Numbered functional requirements and business/security rules	specification.md §§4–5 (FR-01–FR-16, BR-01–BR-14)	Authentication, ownership, CSRF, status, migration, and safe-error rules are testable
UI specification summary	specification.md §6 plus ui-spec.md	Shell, screens, states, roles, breakpoints, accessibility, and no-overflow rules are named
Authorization matrix	specification.md §7	Requester, IT Staff, and Administrator capabilities are explicit; Administrator Ticket access is an intentional grant
Data/migration decisions	specification.md §8/§8.1	Existing Lab 2 identifiers/relationships and deterministic credential backfill are preserved
API contract	specification.md §9 plus api-spec.md	Envelopes, schemas, status codes, CSRF/session boundary, authorization, and safe errors are named
Acceptance criteria and Definition of Done	specification.md §§10–11	AC-01–AC-15 map to executable checks in tests.md
Review assumptions	specification.md §12	Session, crypto, role, migration-password, and report assumptions are recorded

This crosswalk closes the common Spec DD gap where API and UI documents are linked separately but the master specification does not show how the complete contract is assembled.

Test and traceability proof

Gate	Verified result and evidence
Server regression	Merged main @ 92fac36: 15 files / 92 tests. This feature checkout after the explicit Staff Ticket Detail suite split: 16 files / 92 tests. The 16-file capture is follow-up evidence, not a claim about the earlier main commit.
Client regression	15 test files / 50 tests passed in the latest feature-checkout log; Login, ChangePassword, requester detail, queue, staff detail, admin, and responsive suites
Builds	server npm run build and client npm run build passed in the latest feature-checkout logs
Playwright	13 tests passed across desktop/tablet/mobile; authentication, requester regression, staff flow, admin, and responsive visual suites
Migration/seed	Manual .env.test preflight, migrate deploy, and two deterministic seed runs; latest feature-checkout log. The npm seed script itself has no _test guard.
Traceability	tests.md maps AC-01–AC-15 to exact API/UI/security/migration/E2E paths and names the staff-detail assertions in the shared staff queue API suite

Staff queue and Staff Ticket Detail now have explicit API test files. They share a fixture helper so the suite remains deterministic while the repository structure matches the Lab 3 handout.

Part 5–9 evidence map

Part	Visual evidence	Executable / contract evidence
5 Login/password	seven real auth-flow states in the Part 5 pages; desktop/tablet/mobile login captures support Part 9	auth + authorization API, Login + ChangePassword UI, authentication E2E; invalid, inactive, valid, first-login, password change, logout, and direct API gate
6 Staff queue	staff-queue desktop/tablet/mobile captures	queue API/UI/E2E; query, filters, sort, page controls, empty/no-results, retry, and mobile card sorting
7 Staff detail	staff-ticket-detail desktop/tablet/mobile captures	queue/detail API assertions, StaffTicketDetail UI, comments/notes visibility, assignment, priority/status matrix, staff E2E
8 Administration	user-management desktop/tablet/mobile captures	users-admin API, UserManagement UI, authorization and user-administration E2E; duplicate, invalid role, inactive, self, and last-admin guards
9 Zen Green/responsive	full rendered UI spec, completed visual checklist, and 12 responsive screenshots in Part 9	exact tokens, desktop >=992px, tablet 768–991px, mobile <768px, visible focus, labels/live errors, and no page-level overflow

Zen Green token record

Group	Approved values
Primary / secondary / pale green	#006B3C / #0B7A46 / #EAF6EF
Page / surface / primary text	#F5F7F6 / #FFFFFF / #1B2F24
Secondary text / border / read-only	#52665A / #D1DDD6 / #EEF3F0
Error / warning / urgent / low	#C53030 / #D69E2E / #E53E3E / #319795
Breakpoints	Desktop >=992px; tablet 768–991px; mobile <768px; no page-level horizontal overflow

Evidence Appendix: local captures

This selected appendix avoids repeating the UI figures already placed in Parts 5–9. It retains workflow/source evidence, focused typeset contract extracts, selectable verification results and one distinct Requester-resolution capture.

Range	Included evidence
01–07, 12, 18	Project board, main history, contract/release reviews, reviewer record, README, .gitignore, contract changed files and AI-use reflection
09, 14	Readable source extracts: specification authorization matrix and tests.md AC-to-test traceability
Verification table	Server/client tests and builds, 13-test Playwright result, test-database migration and repeated seed; original terminal captures retained in the repository
Requester	Requester public comment and Problem appears resolved; other duplicate UI-state captures are omitted

All screenshot evidence below is retained from local runs or supplied final evidence captures. The report does not count screenshots as tests; test claims remain tied to executable paths and terminal results.

Verification — complete passing test-file lists

Source: artifacts/lab-03/verification/server-test.txt and client-test.txt. These are selectable extracts of the actual feature-checkout logs; the full original outputs remain in those files. Neither is labeled as a post-merge main run.

Server npm test — 16 files / 92 tests	Client npm test — 15 files / 50 tests
tests/lab-03/migration-regression.api.test.ts	tests/lab-02/api.test.tsx
tests/lab-03/auth.api.test.ts	tests/lab-03/StaffTicketQueue.test.tsx
tests/lab-03/comments-notes.api.test.ts	tests/lab-03/StaffTicketDetail.test.tsx
tests/lab-03/users-admin.api.test.ts	tests/lab-02/TicketDetail.test.tsx
tests/lab-02/seed.test.ts	tests/lab-03/UserManagement.test.tsx
tests/lab-02/ticket-detail.api.test.ts	tests/lab-02/MyTickets.test.tsx
tests/lab-03/authorization.api.test.ts	tests/lab-03/App.test.tsx
tests/lab-02/create-ticket.api.test.ts	tests/lab-03/RequesterTicketDetail.test.tsx
tests/lab-02/my-tickets.api.test.ts	tests/lab-02/CreateTicket.test.tsx
tests/lab-03/staff-queue.api.test.ts	tests/lab-03/Login.test.tsx
tests/lab-03/staff-ticket-detail.api.test.ts	tests/lab-03/ChangePassword.test.tsx
tests/lab-02/attachment-validator.unit.test.ts	tests/lab-01/App.test.tsx
tests/lab-01/categories.test.ts	tests/lab-02/ThemeStyles.test.tsx
tests/lab-01/health.test.ts	tests/lab-02/ResponsiveLayout.test.tsx
tests/lab-02/requesters.api.test.ts	tests/lab-02/RequesterSelector.test.tsx
tests/lab-02/ticket-number.unit.test.ts	

Observed totals: server 16 test files / 92 tests passed; client 15 test files / 50 tests passed. No skipped or failed tests are counted as passes.

Verification — builds, E2E, migration and seed

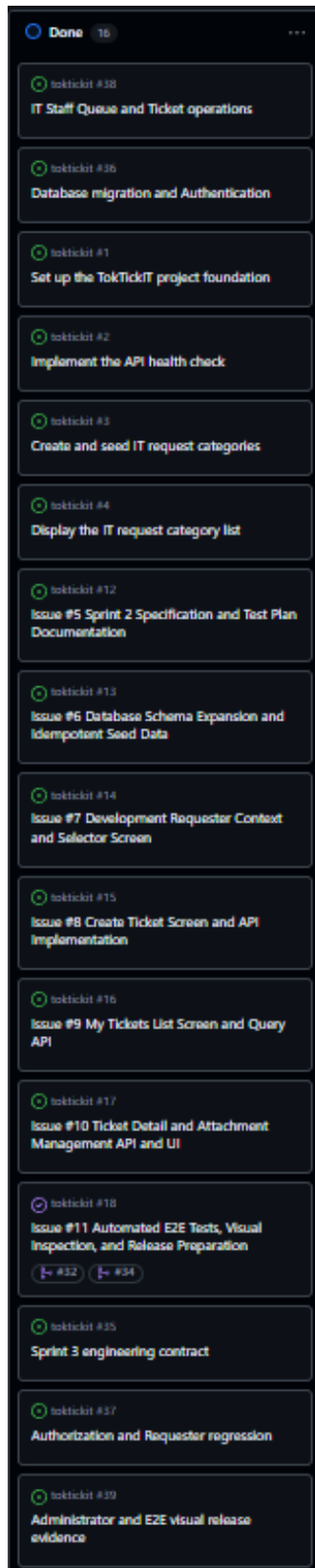
Command	Observed output
server npm run build	TypeScript compiler (tsc); process exited 0
client npm run build	TypeScript compiler and Vite; 37 modules transformed; build completed
npx prisma migrate deploy	5 migrations found; No pending migrations to apply
npm run prisma:seed — twice	Each run: 4 categories, 7 systems, 5 development requesters, ticket counter initialized

Playwright E2E — 13 passed, 0 failed, 0 skipped, 0 flaky. Individual results from artifacts/lab-02/e2e-results.json:

#	Passing test and viewport
1	keeps requester A tickets invisible to requester B (desktop)
2	signs in, creates a ticket, opens detail, and removes an attachment (desktop)
3	covers the requester journey across Create Ticket, My Tickets, and Ticket Detail (desktop)
4	covers the requester journey across Create Ticket, My Tickets, and Ticket Detail (tablet)
5	covers the requester journey across Create Ticket, My Tickets, and Ticket Detail (mobile)
6	completes first-login password setup and shows the Administrator shell (desktop)
7	adds a public comment and records Problem appears resolved without closing the ticket (desktop)
8	captures authentication, user management, staff queue, and staff detail (desktop)
9	captures authentication, user management, staff queue, and staff detail (tablet)
10	captures authentication, user management, staff queue, and staff detail (mobile)
11	opens the shared queue and staff ticket detail with safe communication controls (desktop)
12	keeps queue sorting controls usable with mobile ticket cards (desktop)
13	lists users and supports create, edit, activation, and initial-password reset (desktop)

Original outputs: artifacts/lab-03/verification/{server-build.txt,client-build.txt,migration-seed-final.txt} and artifacts/lab-02/e2e-results.json. Seed safety: npm run prisma:seed has no built-in database guard. Before this recorded run, PowerShell loaded DATABASE_URL from server/.env.test, checked the PostgreSQL protocol and _test marker, set the session variable explicitly, and then Prisma reported toktickit_test before migration and the two seed runs. The transcript's 'Environment variables loaded from .env' is Prisma's dotenv message, not proof that the production .env was selected. Reproduction must verify that the URL's database name ends in _test before running seed; no URL or credential is printed here.

Evidence 01 — Project board with completed Lab 1–3 issues



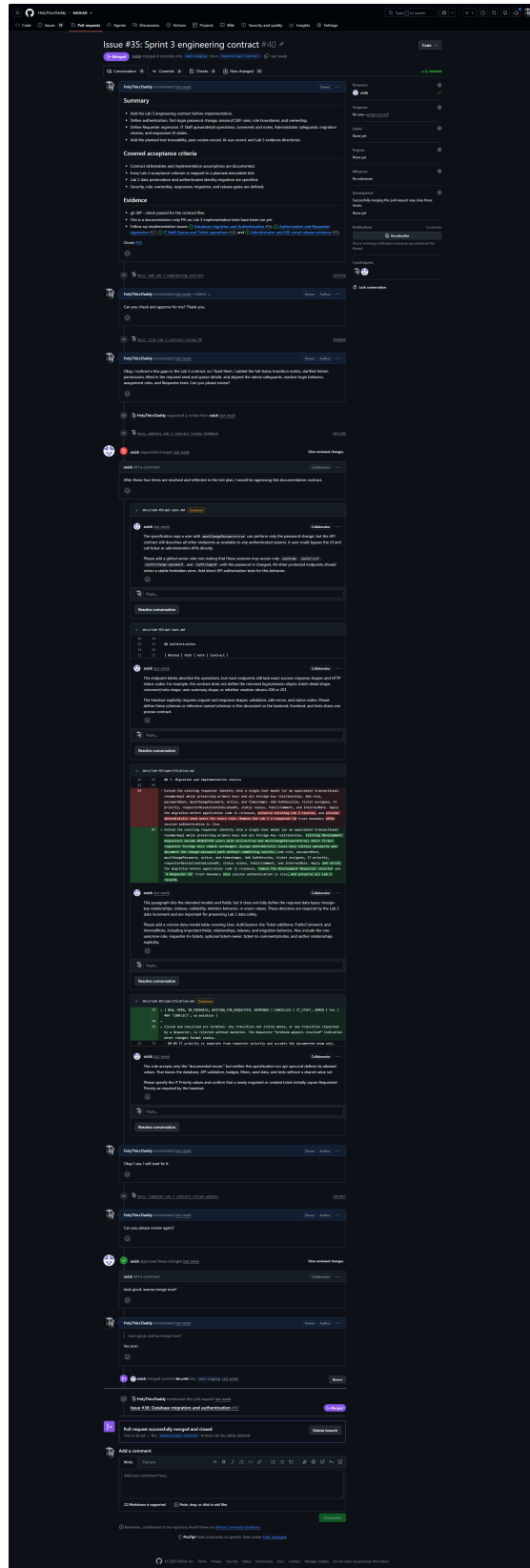
Local verification capture retained in the final evidence set.

Evidence 02 — Main-branch commit history for the reviewed Lab 3 release

<

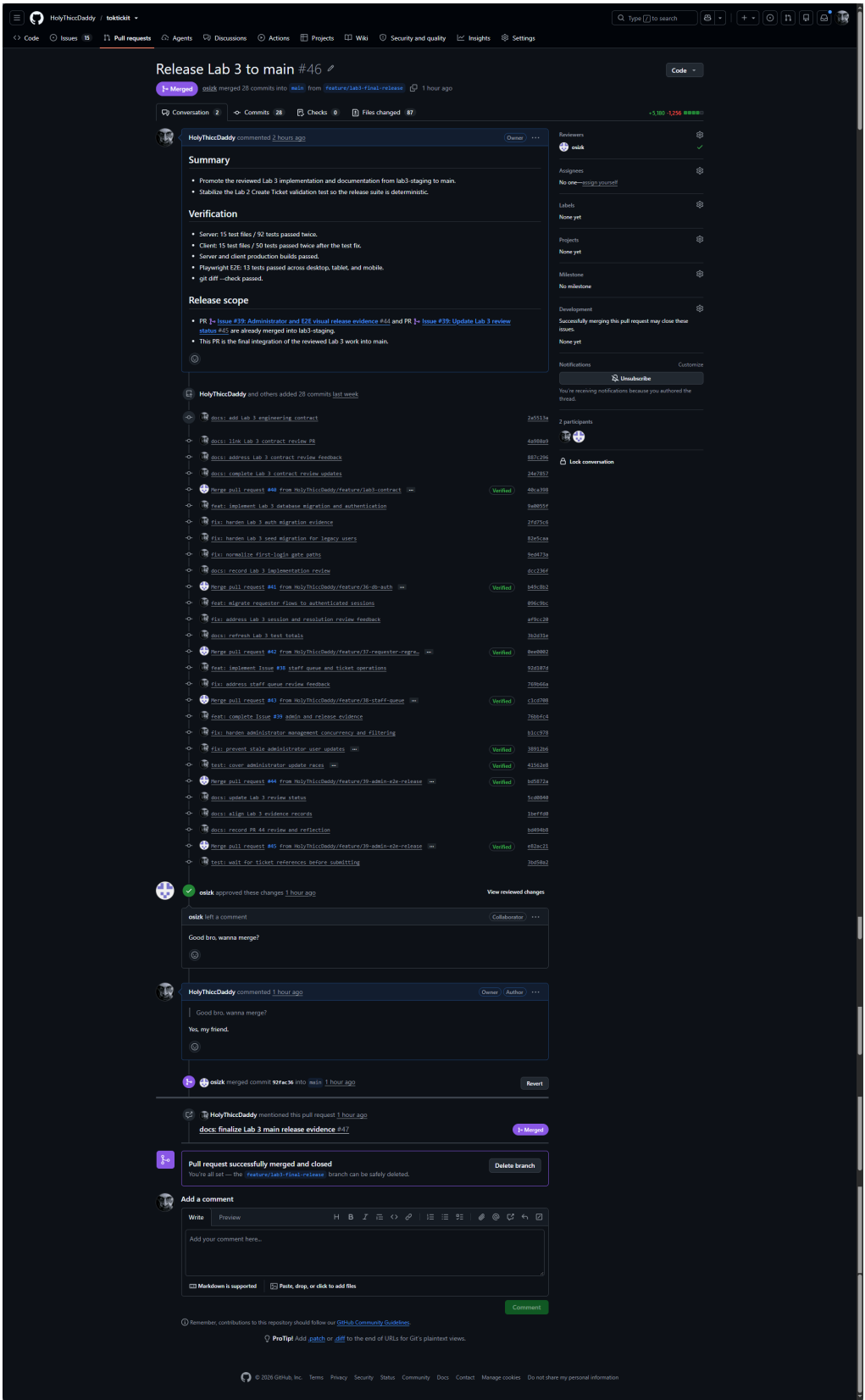
Local verification capture retained in the final evidence set.

Evidence 03 — PR #40 contract discussion, review feedback, and approval



Local verification capture retained in the final evidence set.

Evidence 04 — PR #46 final release approval and merge into main



Local verification capture retained in the final evidence set.

Evidence 05 — Rendered peer-review record with review rounds and approvals

```
1  # Lab 3 - Peer Review Record
2
3  Status: Lab 3 contract, implementation, documentation, and release evidence are approved and integrated into 'main'. PR #44 was approved by @osix in [review #5245822348](https://github.com/HolyThiccDaddy/toktickit/pull/44#pullrequestreview-5245822348) and merged into
4
5  **Author:** Thira Rungruangkaset - GitHub: @HolyThiccDaddy
6  **Peer reviewer:** Ashira Sangkaset - GitHub: @osix
7
8  ## Contract review
9
10 | PR | Scope | Reviewer verdict | Follow-up |
11 |---|---|---|---|
12 | #40 | (https://github.com/HolyThiccDaddy/toktickit/pull/40) | Lab 3 specification, API contract, UI specification, and test plan | Approved by @osix after the second review; merged into 'lab3-staging' as '40ca398' | Contract approval recorded; implementation and rel
13
14 ## Review protocol
15
16 Reviewers should check that the contract covers authentication, first-login password change, role and ownership authorization, staff queue/detail, public comments/internal notes, admin safeguards, migration compatibility, responsive UI, and traceable tests. Record com
17
18 ## Peer review round 1 - 2026-09-12
19
20 The reviewer requested a complete eight-status transition matrix with permitted roles, confirmations, and invalid-transition behavior. The contract now defines NEW, OPEN, IN_PROGRESS, WAITING_FOR_REQUESTER, RESOLVED, CLOSED, REOPENED, and CANCELLED, including terminal
21
22 The reviewer found a contradiction about Administrator Ticket access. The contract now states that the authorization matrix explicitly grants Administrators the same queue and Ticket operations as IT Staff, while keeping user management Administrator-only. The API, UI
23
24 The reviewer requested exact seed quantities, queue query behavior, and Administrator safeguards. The contract now specifies the required active and inactive account counts, realistic assigned and unassigned Tickets, searchable/filterable/sortable fields, pagination m
25
26 The reviewer requested Requester-side tests for comments and the resolution indication. The test plan now maps AC-86 to a Requester Ticket Detail component test and a Requester regression E2E flow that checks ownership rejection and confirms the indication does not set
27
28 The reviewer requested safer inactive-login handling and Administrator assignment eligibility. The API now returns ACCOUNT_INACTIVE only after the submitted password is verified, and assignment accepts only active IT Staff or Administrator users. Public/internal messa
29
30 ## Peer review round 2 - 2026-09-12
31
32 The reviewer requested a global backend first-login gate. The API contract now limits a must-change session to '/auth/me', '/auth/csrf', '/auth/change-password', and '/auth/logout', with 'PASSWORD_CHANGE_REQUIRED' for every other protected endpoint, and the test plan
33
34 The reviewer requested precise API response schemas and success codes. The API contract now defines shared named schemas for sessions, users, tickets, comments, notes, attachments, and pagination, plus a success-status map for every endpoint.
35
36 The reviewer requested complete data-model decisions. The specification now includes a model table with types, nullability, relationships, indexes, deletion behavior, migration mapping, and preservation of Lab 2 identifiers and ownership.
37
38 The reviewer requested the actual IT Priority enum. The contract now defines 'LOW', 'MEDIUM', 'HIGH', and 'URGENT', requires the migrated or newly created Ticket to copy Requested Priority into IT Priority, and maps validation to the API and test plan.
39
40 ## Contract approval - 2026-09-12
41
42 The reviewer approved the corrected contract in [PR #40](https://github.com/HolyThiccDaddy/toktickit/pull/40#pullrequestreview-5186811435). GitHub merged it into 'lab3-staging' as [commit '40ca398'](https://github.com/HolyThiccDaddy/toktickit/commit/40ca3983e786c72d
43
44 ## Implementation review round 1 - 2026-09-12
45
46 In [PR #41](https://github.com/HolyThiccDaddy/toktickit/pull/41#discussion_r3996194389), the reviewer found that seeding only the five hard-coded requester fixtures left additional Lab 2 requesters with the '___MIGRATION_PENDING___' marker. The reviewer also found in [ti
47
48 The reviewer then identified a case-sensitive first-login gate in 'server/src/auth.ts' that could be bypassed with a mixed-case protected path. Commit ['9e0473a'](https://github.com/HolyThiccDaddy/toktickit/commit/9e0473ac499b09ef46ea7b2b2f2fa071d511ed6c) normalizes r
49
50 ## Implementation and release history
51
52 Issue #38 was merged into 'lab3-staging' through [PR #43](https://github.com/HolyThiccDaddy/toktickit/pull/43). Issue #39 added Administrator user management and the remaining release evidence on 'feature/39-admin-e2e-release'. The implementation includes the Administ
53
54 The final Issue #38 verification is recorded in 'docs/lab-03/tests.md': 15 server test files/92 tests, 15 client test files/50 tests, 13 Playwright tests across desktop/tablet/mobile projects, and production builds passed. The reviewed implementation and documentation
```

Local verification capture retained in the final evidence set.

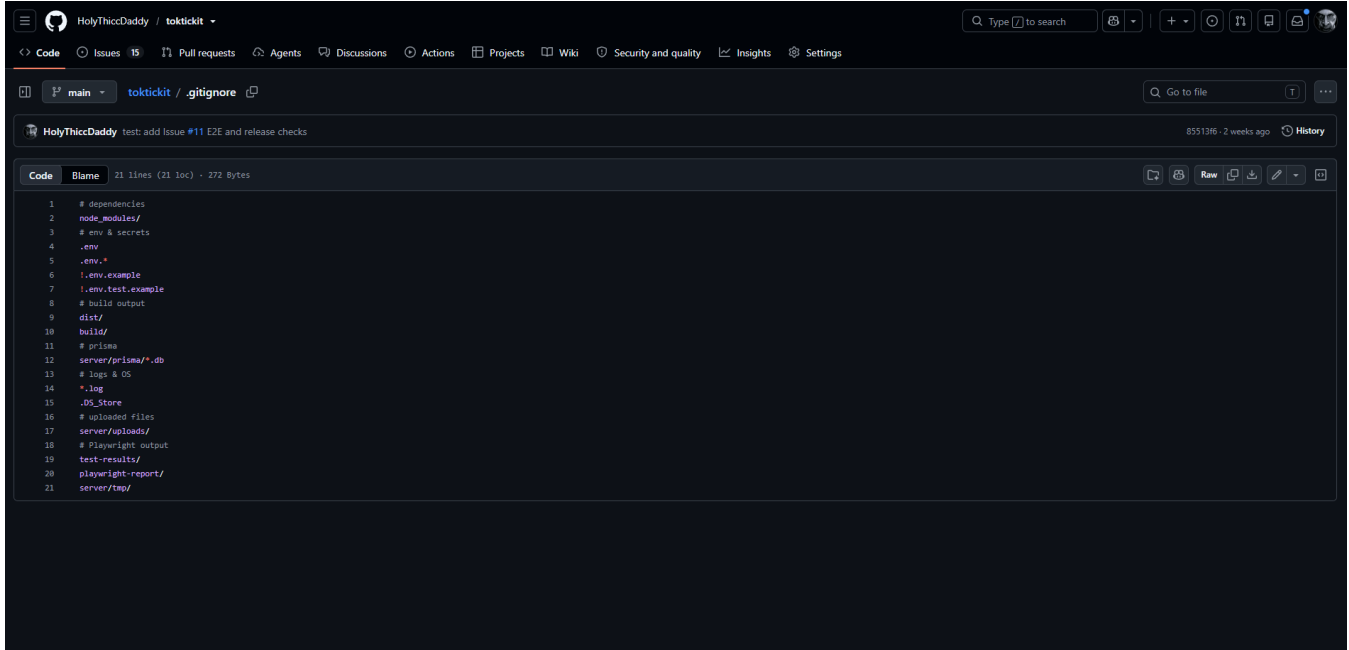
Evidence 06 — Rendered README with setup, verification, and document links

```

1  # taktickit - Lab 3 Authentication & Filtering
2
3  Taktickit is a full-stack IT service-desk application. Lab 3 replaces Lab 2's temporary Development Requester selector with authenticated sessions and adds the complete requester, IT Staff, and Administrator workflows. Requesters manage only their own tickets and attachments.
4
5  # Scope and Technology
6
7  **Frontend:** React 18, TypeScript, Vite, Bootstrap 5
8  **Backend:** Node.js, Express, TypeScript, Prisma ORM
9  **Database:** PostgreSQL
10 **Testing:** Vitest, Supertest, React Testing Library, Playwright
11 **Architecture:** Monorepo with 'client/', 'server/', and repository-root E2E specs
12
13 The released application includes the approved Lab 3 query, ticket detail, communication, and user-management workflow described in 'docs/lab-03/'.
14
15 # Repository structure
16
17 ```text
18 taktickit/
19 ├── client/                # React UI, component tests, and Playwright Abandonmy
20 ├── server/               # Express API, Prisma ORM/migrations, and API tests
21 ├── e2e/                  # Playwright journeys and deterministic setup/teardown
22 ├── docs/lab-02/          # Lab 2 contract, test plan, AI log, and review record
23 ├── docs/lab-03/          # Lab 3 contract, test plan, AI log, and review record
24 ├── artifacts/lab-02/     # Lab 2 test output and resumable/visual evidence
25 ├── artifacts/lab-03/     # Lab 3 resumable/visual evidence
26 ├── output/               # Final submission reports
27 ...
28
29 # Prerequisites
30
31 Node.js "20 or higher" (required by the current Playwright dependency)
32 PostgreSQL running locally on port "5432"
33 A PostgreSQL role that can create databases
34
35 # Installation and environment
36
37 ```bash
38 git clone https://github.com/HolyChicDaddy/taktickit.git
39 cd taktickit
40 cd server
41 npm install
42 copy .env.example .env
43 cd ../client
44 npm install
45
46 Set 'server.env' to a local development database, for example:
47
48 ```env
49 DATABASE_URL="postgresql://taktickit:taktickit@localhost:5432/taktickit-test-db"
50 PORT=3000
51 TACTICKIT_API_URL=http://localhost
52
53
54 Create the dedicated test database before running destructive suites:
55
56 ```bash
57 createdb -U taktickit taktickit_test
58 cd server
59 copy .env.test.example .env.test
60 npm run migrate:dev
61 npm run prisma:seed
62 ...
63
64 'server.env.test' is local-only and ignored by Git. Test setup requires a database name ending in '_test' and writes attachments beneath a test-only temporary directory.
65
66 # Run the application
67
68 ```bash
69 # terminal 1
70 cd server
71 npm run dev
72
73 # terminal 2
74 cd client
75 npm run dev
76
77 The API is available at "http://localhost:3000" and Vite serves the UI at "http://localhost:5173".
78
79 # Verification commands
80
81 Run the smallest relevant suite first, then the full release checks:
82
83 ```bash
84 cd server
85 npm test
86 npm run build
87
88 cd ../client
89 npm test
90 npm run build
91 npm run playwright test
92
93 The Playwright command starts isolated services, resets deterministic fixtures in 'taktickit_test', checks requester, staff, and administrator journeys at desktop/tablet/mobile sizes, and writes JSOR results plus PMO evidence under the 'artifacts/' directories.
94
95 # API surface
96
97 - GET /api/health - service health
98 - POST /api/auth/login - create an authenticated session
99 - POST /api/auth/logout - revoke the current session
100 - GET /api/auth/me - return the current user summary
101 - GET /api/auth/reset - issue a CSRF token for state-changing requests
102 - POST /api/auth/change-password - simulate a first-time password change
103 - GET /api/categories - active ticket categories
104 - GET /api/active-systems - active related systems
105 - POST /api/tickets - create a 'new' ticket owned by the signed-in Requester
106 - GET /api/tickets - session-scoped search, filtering, sorting, and pagination
107 - GET /api/tickets/{id} - read-only ticket detail with public conversation
108 - POST /api/tickets/{id}/attachments - add a validated attachment to an owned ticket
109 - GET /api/attachments/{id}/download - download an active owned attachment
110 - GET /api/attachments/{id} - retrieve an owned attachment with a reason
111 - GET /api/tickets/{id}/comments - read or append public comments on an owned ticket
112 - POST /api/tickets/{id}/requester-resolution - record the Requester's resolution indication
113 - GET /api/staff/tickets/{id}/... - staff/role assignment, IT priority, and status operations
114 - GET /api/tickets/{id}/notes - internal notes for IT Staff and Administrators
115 - GET /api/patch /api/role/users... - Administrator user listing and role account management
116
117 Protected identity is derived only from the server-side 'taktickit_session' cookie; client-supplied requester, owner, author, and role values are ignored. State-changing requests require the server-issued CSRF token. Attachment uploads enforce allowed type, extension,
118
119 # Lab 2 documentation
120
121 [Sprint specification](docs/lab-02/sprint-specification.md)
122 [NEXT API contract](docs/lab-02/api-contract.md)
123 [UI specification](docs/lab-02/ui-specification.md)
124 [Test plan and results](docs/lab-02/test-plan.md)
125 [AI use and reflection](docs/lab-02/ai-use.md)
126 [Peer-review record](docs/lab-02/peer-review.md)
127 [Lab 2 visual evidence](artifacts/lab-02/summaries/)
128
129 # Lab 3 documentation
130
131 [Sprint specification](docs/lab-03/sprint-specification.md)
132 [NEXT API contract](docs/lab-03/api-contract.md)
133 [UI specification](docs/lab-03/ui-specification.md)
134 [Test plan and results](docs/lab-03/test-plan.md)
135 [AI use and reflection](docs/lab-03/ai-use.md)
136 [Peer-review record](docs/lab-03/peer-review.md)
137 [Final submission report](docs/lab-03/ai-final-submission-report.pdf)
138 [Final submission report PDF](docs/lab-03/ai-final-submission-report.pdf)
139
140 The core Lab 3 implementation was integrated into 'main' by release PR #22 ('a5f0b07'). The README/documentation update was prompted by PR #22 ('3d63f97'), and the final evidence/report update was prompted by PR #22 ('3d63f97').
141
142 Lab 3 was integrated into 'main' by Final Release PR #66 ('979c3c7') after peer-reviewed implementation PRs #22-#62 were merged into 'lab-3-staging'.
```

Local verification capture retained in the final evidence set.

Evidence 07 — Repository .gitignore evidence for secrets and generated files



The screenshot shows a GitHub repository interface for 'HolyThiccDaddy / tokickit'. The file '.gitignore' is selected, showing its content. The file contains 21 lines of ignore rules. The repository has 15 issues, and the file was last updated 2 weeks ago.

```
1 # dependencies
2 node_modules/
3 # env & secrets
4 .env
5 .env.*
6 !.env.example
7 !.env.test.example
8 # build output
9 dist/
10 build/
11 # prisma
12 server/prisma/*.db
13 # logs & OS
14 *.log
15 .DS_Store
16 # uploaded files
17 server/uploads/
18 # Playwright output
19 test-results/
20 playwright-report/
21 server/tmp/
```

Local verification capture retained in the final evidence set.

Evidence 09 — focused engineering-contract extract

The approved specification names FR-01–FR-16, BR-01–BR-14, the UI/API contracts, migration decisions, AC-01–AC-15 and Definition of Done. This source extract makes the role boundary readable at normal PDF zoom. The linked source contains the complete text.

[Open complete specification.md](#)

Section 7 — authorization matrix

Capability	Requester	IT Staff	Administrator
Login/logout/current session	Yes	Yes	Yes
Own ticket create/list/detail/attachments	Own only	Queue access	Queue/admin access
Other user's ticket	No	Yes	Yes
Public comments	Own tickets	Any queue ticket	Any ticket
Internal notes	No	Any queue ticket	Any ticket
Claim/reassign/IT priority/status	No	Yes	Yes, by explicit matrix grant
User management	No	No	Yes

Section 6 — UI contract summary

Login and first-login password change replace the development Requester selector. Staff Queue includes search, status/priority/assignee/category filters, sorting and pagination. Staff Detail includes assignment, priority/status changes, public comments and internal notes. Administrator User Management includes create/edit, activation, reset and self/last-admin safeguards. Desktop, tablet and mobile must reflow without page-level overflow.

This is a typeset extract from the tracked Markdown source, not a browser screenshot.

Evidence 12 — PR #40 changed-files view for contract artifacts

The screenshot displays a GitHub Pull Request (PR) #40 titled "Sprint 3 engineering contract #40". The PR is merged and shows changes to various files. The left sidebar lists the files changed, including artifacts, client, docs, and server directories. The main area shows the diff for the selected file, `docs/lab-03/api-spec.md`. The diff highlights changes to the API specification, including status, conventions, and error handling details.

Issue #35: Sprint 3 engineering contract #40

Merged [@stuartmorgan](#) merged 4 commits into `lab3-staging` from `Feature/lab3-contract` last week

Conversation 11 Commits 4 Checks 0 Files changed 13

0 / 13 viewed Submit comments

Filter files...

- artifacts/lab-03/screenshots
- authentication
- staff-queue
- staff-ticket-detail
- user-management
- client/tests/lab-03
- docs/lab-03
 - ai-use.md
 - api-spec.md
 - reviewer.md
 - specification.md
 - tests.md
 - ui-spec.md
- e2e/lab-03
- server/tests/lab-03
 - tests.md
 - ui-spec.md
- e2e/lab-03
- server/tests/lab-03
- e2e/lab-03
- server/tests/lab-03
- e2e/lab-03
- server/tests/lab-03

artifacts/lab-03/screenshots/authentication/.gitkeep

artifacts/lab-03/screenshots/staff-queue/.gitkeep

artifacts/lab-03/screenshots/staff-ticket-detail/.gitkeep

artifacts/lab-03/screenshots/user-management/.gitkeep

client/tests/lab-03/.gitkeep

docs/lab-03/ai-use.md

docs/lab-03/api-spec.md

```
@@ -0,0 +1,20 @@
1 + # Lab 3 AI Use and Reflection
16 + # | Audit release evidence | Check source, logs, screenshots, and final report consistency | To be recorded before release PR |
17 +
18 + ## Reflection
19 +
20 + AI output is treated as a draft. Contract decisions remain subject to the Lab 3 handout and peer review. Security-sensitive behavior is accepted only when executable tests and real terminal evidence confirm it; suggestions that weaken server-side authorization, expose credentials, or invent unsupported requirements are rejected.
```

docs/lab-03/api-spec.md

```
@@ -0,0 +1,136 @@
1 + # Lab 3 API Specification
2 +
3 + Status: Draft contract for peer review before implementation
4 +
5 + ## Conventions
6 +
7 + - Base path: /api.
8 + - JSON requests and responses use UTF-8 and the standard envelope `{ data: ... }` on success.
9 + - Failures use `{ error: { code, message, fieldErrors? } }`. Codes are stable; messages never expose secrets, SQL, filesystem paths, storage keys, or unnecessary account details.
10 + - Browser authentication uses an opaque HttpOnly cookie named `toktickit_session`; the server resolves the user and role from the session.
11 + - GET endpoints are safe. Every authenticated POST, PATCH, and DELETE requires the CSRF token returned by GET `/api/auth/csrf` in `X-CSRF-Token`; the public login request is the exception.
12 + - `401 UNAUTHORIZED` means no valid session; `403 FORBIDDEN` means a valid session lacks the role or ownership; protected ticket resources may return `404 NOT_FOUND` for both missing and unauthorized records.
13 + - Validation is `400 VALIDATION_ERROR`; duplicate or invalid state is `409 CONFLICT`; unexpected failures are `500 INTERNAL_ERROR`.
14 + - A session with `mustChangePassword=true` is authenticated but restricted. Until the password is changed, it may call only `/auth/me`, `/auth/csrf`, `/auth/change-password`, and `/auth/logout`. Every other protected endpoint returns `403 PASSWORD_CHANGE_REQUIRED` without performing a mutation.
```

Local verification capture retained in the final evidence set.

Evidence 14 — AC-to-test traceability (page 1 of 2)

These rows are typeset from the approved tests.md source so the acceptance criterion, layer and executable path can be read without magnifying a full-page code screenshot.

Open complete tests.md

ID	Acceptance criterion	Layer	Planned test path / evidence
T-01	AC-01 valid login and role shell	API + UI + E2E	server/tests/lab-03/auth.api.test.ts; client/tests/lab-03/Login.test.tsx; e2e/lab-03/authentication.spec.ts
T-02	AC-02 invalid/inactive login safety	API + UI + E2E	auth.api.test.ts; Login.test.tsx; authentication.spec.ts
T-03	AC-03 first-login password gate and direct API blocking	API + UI + security + E2E	auth.api.test.ts; authorization.api.test.ts; client/tests/lab-03/ChangePassword.test.tsx; authentication.spec.ts
T-04	AC-04 logout/expiry protection	API + security + E2E	auth.api.test.ts; authorization.api.test.ts; authentication.spec.ts
T-05	AC-05 requester Lab 2 regression/ownership	API + UI + migration + E2E	server/tests/lab-03/authorization.api.test.ts; server/tests/lab-02/create-ticket.api.test.ts, my-tickets.api.test.ts, ticket-detail.api.test.ts; e2e/lab-02/multi-requester-isolation.spec.ts, requester-ticket-flow.spec.ts, responsive.visual.spec.ts
T-06	AC-06 requester public comment/resolution indication and ownership	API + UI + security + E2E	server/tests/lab-03/comments-notes.api.test.ts; client/tests/lab-03/RequesterTicketDetail.test.tsx; e2e/lab-03/requester-regression.spec.ts
T-07	AC-07 shared queue search/filters/sort /pagination/responsive states	API + UI + style + responsive + E2E	server/tests/lab-03/staff-queue.api.test.ts; client/tests/lab-03/StaffTicketQueue.test.tsx; e2e/lab-03/staff-ticket-flow.spec.ts
T-08	AC-08 claim/reassign/IT Priority enum/complete status matrix authorization	API + UI + security + E2E	server/tests/lab-03/staff-ticket-detail.api.test.ts; client/tests/lab-03/StaffTicketDetail.test.tsx; e2e/lab-03/staff-ticket-flow.spec.ts

The final test counts are recorded separately in the readable verification table; this table is the contract mapping, not a test-run screenshot.

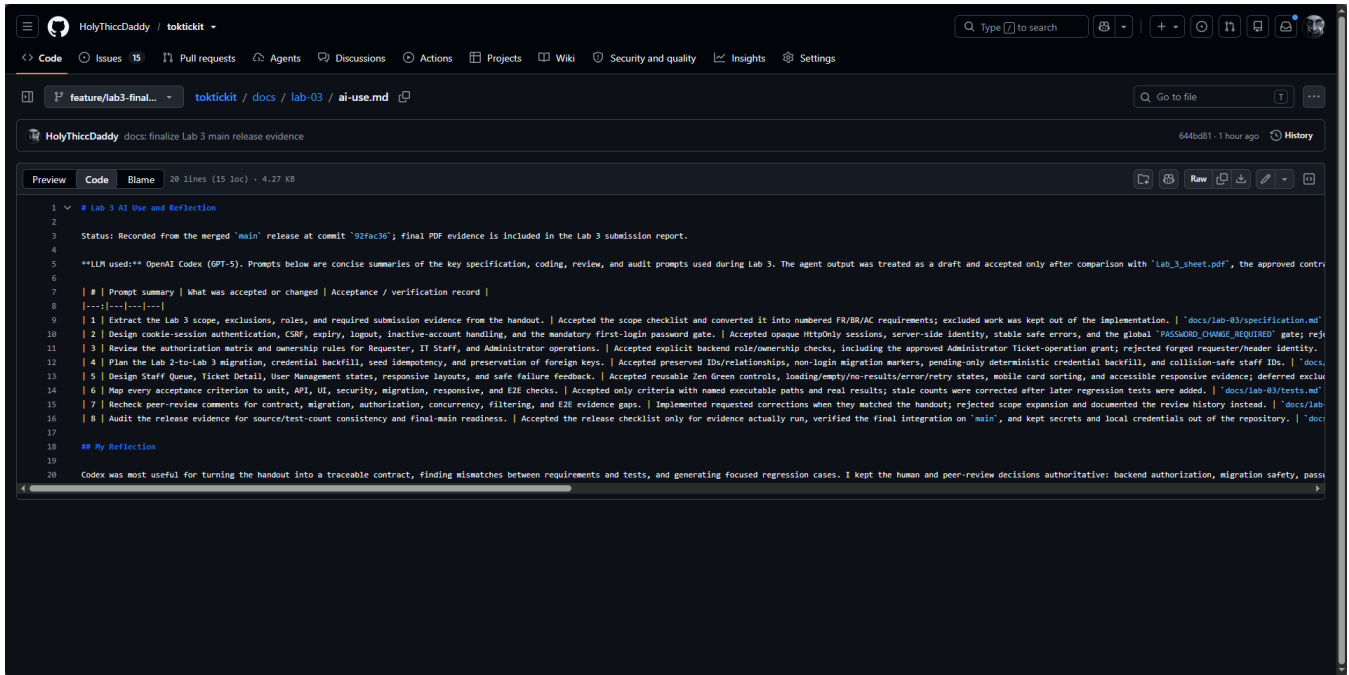
Evidence 14 — AC-to-test traceability (page 2 of 2)

These rows are typeset from the approved tests.md source so the acceptance criterion, layer and executable path can be read without magnifying a full-page code screenshot.

ID	Acceptance criterion	Layer	Planned test path / evidence
T-09	AC-09 public vs internal visibility and append-only validation	API + UI + security + E2E	server/tests/lab-03/staff-ticket-detail.api.test.ts; server/tests/lab-03/comments-notes.api.test.ts; client/tests/lab-03/StaffTicketDetail.test.tsx; e2e/lab-03/staff-ticket-flow.spec.ts
T-10	AC-10 admin user management and activation state	API + UI + E2E	server/tests/lab-03/users-admin.api.test.ts; client/tests/lab-03/UserManagement.test.tsx; e2e/lab-03/user-administration.spec.ts
T-11	AC-11 self-deactivation/self-role-change, last-admin, and deactivated-user safety	API + security + UI	users-admin.api.test.ts; authorization.api.test.ts; UserManagement.test.tsx
T-12	AC-12 migration/data preservation/idempotent seed	Migration + regression	server/tests/lab-03/migration-regression.api.test.ts; migration terminal evidence
T-13	AC-13 forged identity/wrong-role rejection	API + security	server/tests/lab-03/authorization.api.test.ts
T-14	AC-14 responsive no-overflow behavior	UI style + responsive + E2E	client/tests/lab-03/ResponsiveLayout.test.tsx; all Lab 3 E2E projects; artifacts/lab-03/screenshots
T-15	AC-15 release gates	Regression + build + E2E	server/client test and build logs; e2e results; release checklist

The final test counts are recorded separately in the readable verification table; this table is the contract mapping, not a test-run screenshot.

Evidence 18 — Rendered AI-use record and reflection



The screenshot shows a code editor interface for a file named `ai-use.md` located at `docs/lab-03/`. The file content is as follows:

```
1 # Lab 3 AI Use and Reflection
2
3 Status: Recorded from the merged 'main' release at commit '92fac36'; final PDF evidence is included in the Lab 3 submission report.
4
5 **LLM used:** OpenAI Codex (GPT-5). Prompts below are concise summaries of the key specification, coding, review, and audit prompts used during Lab 3. The agent output was treated as a draft and accepted only after comparison with 'Lab_3_sheet.pdf', the approved contract.
6
7 | # | Prompt summary | What was accepted or changed | Acceptance / verification record |
8 |---|---|---|
9 | 1 | Extract the Lab 3 scope, exclusions, roles, and required submission evidence from the handout. | Accepted the scope checklist and converted it into numbered FR/BR/AC requirements; excluded work was kept out of the implementation. | 'docs/lab-03/specification.md'
10 | 2 | Design cookie-session authentication, CSRF, expiry, logout, inactive-account handling, and the mandatory first-login password gate. | Accepted opaque HttpOnly sessions, server-side identity, stable safe errors, and the global 'PASSWORD_CHANGE_REQUIRED' gate; rejected forged requester/header identity.
11 | 3 | Review the authorization matrix and ownership rules for Requester, IT Staff, and Administrator operations. | Accepted explicit backend role/ownership checks, including the approved Administrator Ticket-operation grant; rejected forged requester/header identity.
12 | 4 | Plan the Lab 2-to-Lab 3 migration, credential backfill, seed idempotency, and preservation of foreign keys. | Accepted preserved IDs/relationships, non-login migration markers, pending-only deterministic credential backfill, and collision-safe staff IDs. | 'docs/
13 | 5 | Design Staff Queue, Ticket Detail, User Management state, responsive layouts, and safe failure feedback. | Accepted reasonable Zen Green controls, loading/empty/no-result/error/retry states, mobile card sorting, and accessible responsive evidence; deferred exclusion
14 | 6 | Map every acceptance criterion to unit, API, UI, security, migration, responsive, and E2E checks. | Accepted only criteria with named executable paths and real results; stale counts were corrected after later regression tests were added. | 'docs/lab-03/tests.md'
15 | 7 | Recheck peer-review comments for contract, migration, authorization, concurrency, filtering, and E2E evidence gaps. | Implemented requested corrections when they matched the handout; rejected scope expansion and documented the review history instead. | 'docs/lab
16 | 8 | Audit the release evidence for source/test-count consistency and final-main readiness. | Accepted the release checklist only for evidence actually run, verified the final integration on 'main', and kept secrets and local credentials out of the repository. | 'doc
17
18 ## My Reflection
19
20 Codex was most useful for turning the handout into a traceable contract, finding mismatches between requirements and tests, and generating focused regression cases. I kept the human and peer-review decisions authoritative: backend authorization, migration safety, pass
```

Local verification capture retained in the final evidence set.

Requester evidence — Requester comment and resolution indication

TokTickIT

HomeMy Tickets+ Create Ticket

Jennifer Anderson
REQUESTERSign out

[← Back to My Tickets](#)

NEW

Ticket No.
TKT-2026-000001

TICKET DATE
9/27/2026, 6:13:59 PM

CATEGORY
Software

REQUESTED PRIORITY
MEDIUM

REQUESTER
Jennifer Anderson (jennifer.anderson@example.com)

RELATED SYSTEM
LEB2 App

IT PRIORITY
MEDIUM

Evidence state ticket

A real ticket used for final evidence state capture.

Attachments

0 of 5 active attachments

No active attachments.

Add Attachment

Public conversation

Marked as appears resolved

Indicated 9/27/2026, 6:14:00 PM

Jennifer Anderson · 9/27/2026, 6:14:00 PM

Evidence comment from the requester.

Add a public comment

Post comment

Final-checkout Playwright state capture from the merged Lab 3 release.

Submission close-out

The primary deliverable is output/pdf/LAB_03_FINAL_SUBMISSION_REPORT.pdf. The historical _10-10 filename is not the canonical deliverable. The core report preserves the Lab 2 template; this selected appendix adds contract crosswalks and verification without duplicating the UI-state figures.

The Staff Ticket Detail API suite is now an explicit server/tests/lab-03/staff-ticket-detail.api.test.ts file, matching the Lab 3 minimum repository structure. No unsupported requirement, credential, or hidden UI state is presented as evidence.